PRODUCT RESEARCH · PRD · TECHNICAL BLUEPRINT

# MediChain AI

A decentralised, AI-powered healthcare records and intelligence ecosystem




Complete research, competitive analysis, free-tier build plan, PRD, UI/UX specification, technical specification, roadmaps, cost scenarios (INR) and implementation checklist.

**Version 1.0 · Research date: 7 November 2026**

Prepared for a solo developer building with AI-assisted coding tools. India-first.
No code has been written. This document is the blueprint that precedes coding.

# Contents

**Reading guide and evidence conventions** 3

**Executive summary** 4

**Product vision and positioning** 6

**Market research** 7

**Competitor analysis** 9

**Free vibecoding research (highest priority)** 11

**Recommended technology stack** 14

**Product requirements document (PRD)** 16

**UI/UX design specification** 19

**Technical architecture** 23

**Database and API specifications** 25

**AI/ML implementation strategy** 28

**Blockchain implementation strategy** 30

**Security and regulatory considerations** 32

**Roadmap A: 24-48 hour hackathon MVP** 35

**Roadmap B: full product development** 37

**Cost and infrastructure analysis** 38

**Final recommendations** 40

**Implementation checklist** 41

**Research references and source-quality notes** 43

HOW TO READ THIS DOCUMENT

# Reading guide and evidence conventions

This blueprint is meant to be read by you and handed to a capable AI coding agent. Every substantive statement carries one of four tags so you can see what is solid and what is judgement:

| Tag | Meaning | How to treat it |
|---|---|---|
| [FACT] | Verified in a source retrieved during research (numbered reference in brackets). | Reliable as of 7 Nov 2026, but re-check prices, limits and dates before committing money. |
| [ASSUMPTION] | An assumption made to complete the plan. | Challenge it. Several (e.g. exchange rate, user volumes) change cost numbers. |
| [ESTIMATE] | A calculated or judgement-based estimate. | Planning figure only, not a quote. |
| [RECOMMENDATION] | A recommendation from this analysis. | Opinion with reasoning. You can disagree. |

WARNING

**Source-quality warning.** Many pricing and "free tier" pages found in research are third-party blogs that disagree with each other (e.g. Supabase free-tier bandwidth appears as 5 GB in most sources and 10 GB in one; Gemini free-tier request limits differ between sources and are described as changing by project). Where sources conflict, this document says so. Free tiers in particular change monthly. Re-verify on the provider's own pricing page on the day you build.

ASSUMPTION

**Gaps stated openly.** (1) Part 4 of your brief says to retain free-tool requirements "from the previous master prompt"; that prompt was not available, so Section 6 is built from the requirements listed in Part 4 itself. (2) Some competitor rows (Apple Health, Microsoft, OpenMRS/Bahmni, MedRec) rely on background knowledge rather than a fresh November 2026 source; they are marked "not re-verified". (3) Legal points are research summaries, not legal advice; get an Indian health-data lawyer before handling real patient data.

SECTION 2

# Executive summary

**What MediChain AI is.** A hybrid Web2 + AI + Web3 platform where patients hold a unified medical history, AI turns uploaded reports into structured, comparable data, and a blockchain anchors document fingerprints so any report can be proven unmodified.

## The five findings that should change how you build

- **1. The market moved under this idea in the last five months.** [FACT] India launched Aarogya Setu 2.0 on 29 June 2026 as a government Personal Health Record app with ABHA management, consent-based sharing, AI health insights, smart reports and AI-powered record digitisation, using Google's Gemma 4 and open Medical Data Toolkit to extract lab results and map them to FHIR [8][9]. Eka Care already offers a free, ABDM-approved PHR with AI insights and lab-report trends [10]. "Unified records + AI summary of a lab report" is now table stakes and free. It cannot be your differentiator.
- **2. ABDM scale is large, so interoperate rather than compete.** [FACT] About 96 crore ABHA numbers existed by August 2026 and over 100 crore health records were linked by May 2026 [5][6][7]. A product that ignores ABDM is ignoring the national network; a product that plugs into it inherits distribution.
- **3. Blockchain earns its place only in narrow roles.** Anchoring document fingerprints (tamper evidence, independent timestamps) is a defensible use. Storing permissions on-chain is mostly theatre unless the backend cannot bypass it, and blockchain does not fix interoperability or authenticity of a patient-uploaded file. Peer-reviewed reviews describe design trade-offs and limited real-world evaluation [20]. Recommendation [RECOMMENDATION]: hash anchoring (batched in production), off-chain access control, signed issuance by labs and doctors as the real value.
- **4. Privacy dictates the free-tier plan.** [FACT] Google states that paid Gemini API tiers keep prompts out of training, implying free-tier prompts may not be [15]. Never send real patient documents to a free hosted LLM. Use synthetic reports for the hackathon and a self-hosted open model or paid, contractually private API for any real data.
- **5. Regulation is imminent, not distant.** [FACT] DPDP Rules, 2025 were notified on 13 November 2025. Consent Manager provisions (Rule 4) commence 13 November 2026, six days after this document; the main obligations (notice, consent, security safeguards, breach reporting) commence 13 May 2027 [1][2]. Design consent records, audit logs (one-year minimum retention) and breach response in from day one.

## Verdict on the concept

The concept is **feasible and worth building as a hackathon demonstration and as a focused product wedge**, but not as a general-purpose "do everything" PHR. The recommended wedge is **verifiable health documents**: reports and prescriptions that labs and doctors sign, patients control, and anyone authorised can verify, with transparent access history and a doctor-ready longitudinal summary. Everything else (OCR, summaries, chat) is commodity capability you assemble from free or cheap components.

## What you can realistically do

| Goal | Feasible? | Realistic effort (solo, AI-assisted) |
|---|---|---|
| 24-48 h hackathon demo of all three pillars with synthetic data | Yes, if scope is cut as in Section 15 | 24-36 focused hours |
| Public beta with real users, ABHA login (M1) | Yes, but needs ABDM sandbox exit, security audit and legal review | 4-6 months [ESTIMATE] |
| Full vision (labs, doctors, ABDM M2/M3, emergency access, signed Rx) | Yes as a phased product; not solo in one pass | 9-15 months [ESTIMATE] |

**RECOMMENDATION**

**Recommended stack in one line.** Next.js + TypeScript + Tailwind + shadcn/ui, FastAPI (Python) as the single backend, PostgreSQL via Supabase with **SQLAlchemy only** (drop Prisma), pgvector, Supabase Auth, private encrypted storage, PaddleOCR or a vision model for extraction, Google Medical Data Toolkit for FHIR mapping, Hardhat 3 + Solidity + viem on a testnet (Polygon Amoy or Base Sepolia), and wagmi only when doctors or labs must sign with wallets.

SECTION 3

# Product vision and positioning

**Vision.** Every person in India can carry a complete, verifiable medical history, understand it, and decide precisely who sees it, with proof when something is shown or changed.

## Positioning after competitive research

Because government and private PHRs already store and summarise records, MediChain AI positions itself as the **trust layer and clinician workflow on top of records**, not as another place to dump PDFs.

| Question | Answer |
|---|---|
| Who is it for first? | Chronic-condition patients (diabetes, thyroid, kidney, cardiac) with years of lab reports, and the doctors who see them. Their need for trends and verified history is strongest. |
| What is the unique promise? | "Every report in your history is provably unaltered, every access is on a log you can read, and your doctor gets a one-page trend summary before you walk in." |
| What do we deliberately not do? | Diagnose, prescribe, replace ABDM, or hold health data on a public chain. |
| How do we coexist with ABDM? | Phase 2 adds ABHA login (M1) and consent-based record fetch (M3 HIU). Our own consent records mirror ABDM concepts so migration is cheap. |

## Product objectives and measurable targets

| Objective | Metric | Target (hackathon) | Target (beta, A) |
|---|---|---|---|
| Fast report understanding | Upload to summary latency (p50) | < 45 s | < 30 s |
| Extraction trustworthiness | Analyte-level accuracy on a 50-report gold set | Measured, not claimed | ≥ 95% on printed reports; every value human-confirmable |
| Verification works | Hash mismatch detected on tampered file | 100% in demo | 100% |
| Patient control | Grant/revoke time to effect | < 2 s | < 2 s |
| Adoption signal | Users with ≥ 3 reports uploaded | n/a | 40% of activated users |

SECTION 4

# Market research

## 3.1 India: the digital-health backbone

| Indicator | Value | Date / source |
|---|---|---|
| ABHA numbers created | 95.99 crore; 96.43 crore | 31 Jul 2026 [5]; 12 Aug 2026 [6] |
| Health records linked to ABHA | > 100 crore (50 crore in Feb 2025; ~10 crore added every 2-3 months) | May 2026 [7] |
| Registered facilities / professionals | 5.47 lakh facilities; 10.50 lakh professionals | 12 Aug 2026 [6] |
| Integrated health-tech solutions | > 450 | May 2026 [7] |
| Government PHR | Aarogya Setu 2.0 launched 29 Jun 2026 with AI insights and record digitisation | [8][9] |

**[FACT]** Records stay with the entity that created them (hospital, lab, insurer) and move only through the patient's revocable, time-bound consent. This is the ABDM model, and any parallel consent design you build should resemble it.

## 3.2 Market gaps that remain open

**[ASSUMPTION]** The following gaps are inferred from the competitor evidence in Section 5 and from the structure of the ecosystem. They are **hypotheses to validate with 15-20 interviews** (patients with chronic conditions, 5 GPs, 2 diagnostic labs) before investing beyond the hackathon.

- **Authenticity, not just storage.** PHRs store whatever the user uploads. A patient-uploaded PDF proves nothing about origin. Signed issuance by the lab or doctor is a gap that hashes alone cannot close.
- **Access transparency.** ABDM is consent-driven, but a patient-readable, plain-language "who saw what and why" timeline with alerts is a UX opportunity.
- **Clinician-ready synthesis.** Doctors need a one-page, source-linked trend summary, not a folder of PDFs. Eka and HealthPlix focus on the doctor's own EMR notes rather than cross-provider synthesis [10][11].
- **Messy legacy data.** Smartphone photos and scans of Indian lab reports are noisy. A peer-reviewed 2025 study of Indian obstetric reports found PaddleOCR clearly more accurate than Tesseract and compact multimodal models more accurate still [19]. Reliable extraction with human confirmation remains genuinely hard.

## 3.3 Adoption barriers and technical challenges

| Barrier | Why it matters | Mitigation |
|---|---|---|
| Cold start / network effect | Doctors will not check yet another portal | Doctor view requires no install: link + OTP; summary exports to PDF |
| Lab and hospital integration | ABDM M2/M3 certification is 6-9 months greenfield **[ESTIMATE]** [13] | Start as a patient-side app; add M3 (HIU) later |
| Extraction errors | A wrong HbA1c is clinically dangerous | Show source crop, units, confidence; require confirmation for out-of-range values |
| Trust and privacy | Health data is the most sensitive category | Encrypt at rest and per file, one-year audit logs, minimal on-chain data, no free-tier LLM on real data |
| Regulatory load | DPDP, ABDM audit, CERT-In reporting | Plan compliance as features (Section 14) |

## 3.4 Commercial opportunities (hypotheses)

| Model | Payer | Evidence / comparator | Fit |
|---|---|---|---|
| Free patient app + paid clinic subscription | Doctors, clinics | Eka Doc Plus ₹16,999/yr, Pro ₹18,749/yr, Clinic Pro ₹1,00,000/yr [11]; Practo Ray ~₹11,988/yr per one third-party page | Strong; proven in India |
| Verified-report issuance for labs | Diagnostic centres | No public price comparator found | Promising; needs lab pilots |
| Verification API for insurers / employers | Insurers, TPAs | Not researched; NHCX is ABDM's claims layer [13] | Later; large compliance burden |
| Patient premium (family vaults, trend reports) | Patients | Consumers expect free PHRs [10] | Weak alone |

## 3.5 Does blockchain create genuine value here?

The research brief asks for an honest answer. Short version: **sometimes, in one narrow role.**

| Claimed benefit | Does blockchain deliver it better than a database + cryptography? | Verdict |
|---|---|---|
| Tamper-evident documents | A signed hash in a database proves integrity only as long as you trust the operator. An independent public anchor lets anyone detect after-the-fact edits or backdating by the operator itself. | Real, modest value |
| Independent timestamp | RFC 3161 timestamping authorities do the same cheaply; a chain avoids depending on one authority. | Equivalent; chain is easier to demo |
| Authenticity of origin | Needs the issuer's digital signature and a registry of issuer keys. A chain stores the signature, it does not create trust in the issuer. | Chain is optional; signing is essential |
| Patient-controlled access | Enforcement still happens where the file and decryption keys live. An on-chain permission the server can ignore protects nothing; revocation cannot un-share data already read. | Mostly theatre unless keys are controlled per grantee |
| Interoperability | Solved by FHIR and ABDM, not by ledgers. Systematic reviews describe design trade-offs and limited evaluation of effectiveness [20]. | No benefit |
| Right to erasure / DPDP | Immutable ledgers conflict with erasure duties if personal data is on-chain [20]. Hashes with per-document salts avoid this. | Manageable only with off-chain data |

**RECOMMENDATION**

Keep blockchain in the product only as a **tamper-evidence and issuer-registry layer**. Say so on the pitch slide. A judge or investor who knows the field will trust you more for stating the limits.

SECTION 5

# Competitor analysis

Evidence is graded: **[FACT]** means seen in a current source; "NR" means not re-verified in November 2026 (background knowledge).

## 4.1 Detailed profiles

### ABDM / ABHA / Aarogya Setu 2.0 (National Health Authority)

**[FACT]** **Features:** ABHA management, access and sharing of records with consent, AI health insights, smart reports, wearable integration, scan-and-register OPD, scan-and-pay, medication reminders, family profiles [8][9]. Uses Gemma 4 and the open Medical Data Toolkit to identify record type, extract lab test names, methods and results, and map to FHIR [8].

**Audience:** every Indian citizen. **Business model:** public infrastructure; hospitals receive incentives per linked record under the DHIS scheme [4 PIB]. **Strength:** reach (96 crore ABHA), legitimacy, free. **Weakness / gap:** record authenticity and access-transparency UX for a clinician workflow are not documented in sources found.

### Eka Care (Orbi Health)

**[FACT]** Free patient PHR with ABHA creation, report management, vitals tracking, AI insights and a health bot; paid EMR for doctors (₹16,999 to ₹1,00,000 per year by plan); developer APIs for ABHA, consent, FHIR, OCR and lab parsing; described as ABDM-compliant [10][11].

**Strength:** mature, integrated, ABDM-approved, developer platform. **Weakness (from a user review):** document recognition needs improvement. **Implication:** Eka can be a *supplier* via API as easily as a competitor.

### HealthPlix

AI-assisted EMR for doctors; pitched to 10,000+ doctors in India; multilingual prescription printing in 14 regional languages [12]. Pricing now on request per one 2026 comparison page. **[FACT]** Reported (Inc42) to be in acquisition talks with Practo at $25-30 million; deal status not verified [12].

**Gap:** doctor-side tool, not a patient-owned longitudinal vault.

### Practo

Marketplace plus SaaS: doctor discovery, online consults, diagnostics, medicine delivery; Practo Ray practice-management software sold to clinics [12]. Revenue streams reported as subscriptions, commissions and advertising. **Gap:** patient data lives inside Practo's ecosystem.

### Apple Health / Health Records (NR)

Strong on-device privacy and wearables; clinical-records import depends on supported provider networks, which is limited in India. **Gap:** weak local lab ecosystem and no doctor-side workflow.

### Google (NR except open tools)

**[FACT]** Google contributes open Medical Data Toolkit and Gemma 4 to Indian digital health [8]. **Implication:** free, open building blocks for you.

### Microsoft healthcare (NR)

Enterprise cloud and clinical AI aimed at hospitals, not individual patients. Low overlap.

### OpenMRS and Bahmni (NR) / AMRIT

Open-source EHR/HIS used by hospitals; Bahmni and AMRIT have ABDM integrations (AMRIT's documented M1-M3 journey includes FHIR bundle generation and HIU consumption with sandbox certification [13 AMRIT]). **Implication:** reference architecture for ABDM integration; potential institutional hosts.

### Blockchain health projects (MedRec, others)

MedRec (MIT, Ethereum) stored only metadata and permissions on-chain, keeping records off-chain; version 2 reduced on-chain data for scalability [20]. Reviews report that most published designs discuss benefits without effectiveness evaluation [20]. **Lesson:** minimal on-chain footprint, and adoption, not cryptography, is the hard part.

## 4.2 Comparison matrix

| Capability | Aarogya Setu 2.0 / ABDM | Eka Care | HealthPlix | Practo | Apple Health (NR) | MediChain AI (target) |
|---|---|---|---|---|---|---|
| Patient PHR | Yes | Yes (free) | No (doctor EMR) | Yes (inside Practo) | Yes | Yes |
| ABHA / ABDM native | Native | Approved | Doctor-side | Partial (NR) | No | Phase 2 (M1, M3) |
| AI report extraction | Yes (Gemma 4 + toolkit) | Yes | Partial | Limited | No local OCR | Yes (commodity) |
| Lab trend charts | Insights / vitals | Yes | EMR-based | Limited | Yes (wearables) | Core, configurable ranges |
| Doctor workflow | Sharing | Paid EMR | Core | Core (Ray) | None | Summary + verification |
| Cryptographic report authenticity | Not documented in sources | Not documented | No | No | No | **Core differentiator** |
| Patient-readable access log | Consent-based; log UX not documented | Not documented | No | No | Partial | **Core differentiator** |
| Price to patient | Free | Free + IAP | n/a | Free / plans | Free | Free |
| Price to doctor | Free | ₹16,999-₹1,00,000/yr | On request | ~₹12k/yr (one source) | n/a | Free viewer; clinic tier later |

## 4.3 Where MediChain AI can differentiate

- **Signed issuance.** Labs and doctors sign reports/prescriptions; anyone authorised verifies origin and integrity in seconds, without trusting MediChain.
- **Patient-readable audit trail** with plain-language reasons and alerts, anchored periodically so we cannot silently edit it.
- **Doctor one-pager.** Source-linked trends and report-to-report deltas generated before the consultation.
- **Open-source-first pipeline** (PaddleOCR, Medical Data Toolkit, self-hostable Gemma class models) so privacy-sensitive users and institutions can self-host.

> **WARNING**
>
> **Strategic risk.** The two biggest incumbents on the patient side are free and state-backed. If validation interviews show patients are content with Aarogya Setu 2.0's AI features, pivot the wedge to **lab/doctor-side signed issuance and verification** (B2B) rather than a patient app.

SECTION 6

# Free vibecoding research (highest priority)

> **WARNING**
>
> **Read first.** Free tiers change monthly and sources disagree. Treat every number below as "last seen in a source from September to November 2026". Before building, spend 20 minutes confirming each limit on the provider's own page. Also: **free hosted LLMs are for code and synthetic data only.** Never send real patient documents to a free-tier API.

## 6.1 Free AI coding tools (agentic and IDE)

| Tool | What is free | Limits / catches | Role in this build |
|---|---|---|---|
| Gemini CLI | Google-account login, no card; sources cite 1,000 to 1,500 requests per day on a Flash-class model [15][16] | Sources conflict on exact numbers; one repository notes a transition of Google's free coding access toward an "Antigravity" CLI from 18 Jun 2026 [16]. Free-tier data handling differs from paid. | **Primary agent** for scaffolding and bulk edits |
| OpenCode | Open-source agent (very large GitHub following per 2026 roundups); free "Zen" models; BYOK for 75+ providers; works with local Ollama models [16] | Free model roster rotates; some models are rate-limited | **Secondary agent**; hedges against Gemini rate limits |
| Kilo Code / Cline | Open-source VS Code agents; free gateway or provider models appear regularly [16] | Free models change; BYOK otherwise | In-editor agent with diff review |
| GitHub Copilot Free | 2,000 completions + 50 chat/agent requests per month [16] | Small quota; usage-based billing began 1 Jun 2026 for paid plans [16]. Students and educators can get Pro via the Student Pack | Autocomplete; code review |
| Google Antigravity (IDE) | Public-preview agentic IDE reported free with credits [16] | Preview terms can change | Optional |
| Aider / Continue + Ollama | Fully free with local models | Needs a capable GPU or small models | Offline fallback |

## 6.2 Recommended free AI coding setup

- **Editor:** VS Code with Cline or Kilo Code, plus Copilot Free for completions.
- **Agent of record:** Gemini CLI for long, multi-file tasks; OpenCode as backup. Keep this PDF and a short `AGENTS.md` in the repo root so every agent starts with the same context.
- **Workflow (spec-driven, vertical slices):** (1) agent reads the PDF section for one slice, (2) writes tests or an API contract first, (3) implements, (4) you run it and commit. One slice = one commit = one short prompt. Do not ask an agent to "build the app".
- **Rate-limit hygiene:** batch edits into few large requests, keep context files small, switch agent when one throttles. Budget roughly 100 to 300 agent requests for a 36-hour hackathon **[ESTIMATE]**.
- **Safety rules for agents:** never paste real patient data; keep secrets in `.env` and out of prompts; review every smart-contract and auth change by hand.

## 6.3 Free AI model options (inside the product)

| Need | Free option | Facts and limits | Use for |
|---|---|---|---|
| Vision/text extraction and summaries | Gemini API free tier, Flash-class models | Google lists free access for selected models; limits are per project and shown in your AI Studio dashboard [15]. Free tier has lower rate limits and limited caching; paid tier needed to keep prompts out of training [15]. | Hackathon with **synthetic** reports only |
| Privacy-preserving extraction | Gemma 4 open weights, self-hosted (Ollama or vLLM) | Google's own announcement says Gemma 4 powers Aarogya Setu 2.0 record processing [8]. Needs GPU or a small variant on CPU. | Production path for real data **[RECOMMENDATION]** |
| Embeddings | Gemini Embedding 2 (free tier listed) [15]; local sentence-transformers | Local models avoid sending text out | pgvector chunks |
| Chat assistant | Same as extraction; run guardrail prompt | Free tier suits demo traffic only | Hackathon demo |

## 6.4 Free OCR options

| Engine | Evidence | Verdict |
|---|---|---|
| PaddleOCR (PP-OCRv5/v6, Apache 2.0) | In a 2025 study on 60 smartphone-quality Indian ultrasound reports: character error rate 0.111 vs Tesseract 0.189 [19]. PP-OCRv6 released June 2026 with small variants [19 Unstract]. Includes table/layout recognition. | **Default OCR** for self-hosted pipeline |
| Tesseract 5 | Weaker on noisy phone photos and tables (CER 0.189) [19], but tiny, fast and CPU-only | Fallback for clean scans |
| Compact multimodal LLMs (Gemma-class, Gemini Flash) | Same study: compact multimodal models were more accurate than classical and neural OCR pipelines on noisy reports [19] | **Best accuracy**; use with confirmation UI |
| PDF text layer (pdfplumber / pypdfium2) | Most lab PDFs are digital. Extracting the text layer is exact and free | **Try first**, OCR only if empty |
| Google Medical Data Toolkit (open source) | Identifies record type, extracts lab names, methods and results, and maps to FHIR; initial release optimised for lab reports and observations; free for developers [8] | Evaluate on day 1 of Phase 2 **[RECOMMENDATION]** |

**WARNING**

**Memory trap.** Render's free web service has 512 MB RAM [18]. PaddleOCR plus model weights may not fit. For the hackathon use the PDF text layer plus Gemini vision on synthetic reports; for production run OCR on a small paid instance or a worker with at least 2 GB **[ESTIMATE]**.

## 6.5 Free database, storage and auth

| Service | Free tier (last verified) | Catches |
|---|---|---|
| Supabase Free | 500 MB database, 1 GB file storage, 50,000 MAU, ~5 GB egress (one Aug 2026 source says 10 GB), 2 active projects, 500K Edge Function calls [14] | Projects pause after about 1 week of inactivity; no daily backups; 1 GB holds roughly 200 PDFs of 5 MB. Keepalive pings or Pro ($25/mo) needed for anything real |
| Render Postgres Free | 1 GB | Expires 30 days after creation [18]. Do not use for anything you keep |
| Neon (NR) | Serverless Postgres with a free plan | Not re-verified; acceptable fallback |

## 6.6 Free blockchain testnet infrastructure

| Item | Detail | Source |
|---|---|---|
| Polygon Amoy | Chain ID 80002, native test token POL, explorer amoy.polygonscan.com; the only Polygon testnet still operated [17] | [17] |
| Base Sepolia | Coinbase's L2 testnet; ETH from rate-limited faucets (Alchemy, QuickNode, others); Circle faucet for test USDC [17] | [17] |
| Faucet drips | Alchemy Amoy faucet: about 0.1 POL per 24 h without login; other sources cite 0.5 POL with a free account; QuickNode: once per 12 h [17]. Amounts differ by source and over time | [17] |
| Ethereum Sepolia | One source states support runs through 30 Sep 2026 with a successor planned; avoid depending on it [17] | [17] |
| RPC | Free RPC from Alchemy, QuickNode or public endpoints; premium limits cost money | [17] |

**WARNING**

**Testnet is not production.** Testnet tokens have no value and cost nothing; congestion and resets can occur. On mainnet every anchoring transaction costs real gas. A hash-registration transaction is small (**[ESTIMATE]** roughly 50,000 to 80,000 gas), but you must measure gas on the testnet and price it against the live gas price before launch. Section 13 shows batching to keep this negligible.

## 6.7 Free deployment

| Platform | Free tier | Commercial use? | Use |
|---|---|---|---|
| Vercel Hobby | 100 GB transfer, 1M function invocations [18] | **No**: personal, non-commercial only [18] | Hackathon frontend |
| Cloudflare Pages / Netlify Free | Generous limits; Netlify uses monthly credits [18] | Allowed [18] | Frontend for a real beta |
| Render Free web service | 512 MB, 750 hours/month, sleeps after 15 min idle, ~1 min cold start, ephemeral disk [18] | No stated restriction, but docs say not for production [18] | Hackathon FastAPI (wake it before the demo) |
| GitHub Pages | Free for public repos | Not for businesses [18] | Docs only |

## 6.8 Free-stack verdict and expected cost

| Phase | Realistic spend | Notes |
|---|---|---|
| Hackathon (24-48 h) | **₹0** | Everything above fits. Possible extra: a domain (~₹700-1,000/yr) **[ESTIMATE]** |
| Private beta, under 50 users, synthetic or consented data | ₹0-₹3,000/month | Supabase keepalive or Pro; real data requires privacy-safe AI (not free Gemini) |
| Real patient data | See Section 17 | Free tiers are no longer acceptable: backups, SLAs, audit logs, private inference |

SECTION 7

# Recommended technology stack

Your preliminary stack is close but has avoidable complexity. The guiding rule: **one language per tier, one source of truth for the schema, one place where authorisation is enforced.**

## 7.1 Layer-by-layer evaluation

| Layer | Your choice | Verdict | Recommendation and reasoning |
|---|---|---|---|
| Frontend | Next.js + TypeScript | Keep | App Router, server components for dashboards, client components for charts and upload. Largest ecosystem for AI agents to generate correctly. |
| Styling / UI | Tailwind + shadcn/ui | Keep | Own the components; theme via CSS variables to reach the Section 9 palette. Avoid default shadcn look by replacing tokens and typography. |
| Backend | FastAPI (Python) | Keep | The AI/OCR/FHIR tooling is Python (PaddleOCR, Medical Data Toolkit, pgvector clients). One Python service avoids a second backend. |
| ORM | Prisma or SQLAlchemy | **Choose SQLAlchemy only** | Using both means two schema definitions and two migration systems against one database, which will drift. Prisma is TypeScript-only and would force Next.js to touch the DB directly, bypassing FastAPI authorisation. Use SQLAlchemy 2.x with Alembic migrations; generate TypeScript types from FastAPI's OpenAPI schema for the frontend. |
| Database | PostgreSQL | Keep | Relational integrity, row-level security, JSONB for FHIR, pgvector in the same engine. |
| Auth | Supabase Auth or equivalent | Keep for MVP | Email OTP/magic link and JWTs verified in FastAPI. Plan to add ABHA login (ABDM M1) in Phase 2. Use Supabase RLS as defence in depth even though FastAPI is the primary gate. |
| File storage | Supabase Storage | Keep, with changes | Private bucket only; store **application-encrypted** blobs (Section 10). Free 1 GB is small [14]; abstract behind an interface so S3-compatible storage (AWS S3 Mumbai, Cloudflare R2) is a drop-in. |
| OCR | PaddleOCR/Tesseract | Refine | PDF text layer first; then vision model (demo) or PaddleOCR (self-hosted). Drop Tesseract unless CPU-only and documents are clean [19]. |
| LLM | Open-source or hosted | Split by data type | Gemini free Flash for synthetic demo; Gemma 4 self-hosted or a paid zero-retention API for real data. |
| Vector DB | pgvector | Keep | Enough for under a few hundred thousand chunks; no extra service. |
| Contracts | Solidity + Hardhat | Keep (Hardhat 3) | Hardhat 3 reached its first stable release and ships a viem plugin [22]. Foundry is an equally good alternative if you prefer Solidity-native tests. |
| Chain | Polygon Amoy / Base Sepolia | Keep one | Pick **one**. Polygon Amoy suits India familiarity **[ASSUMPTION]**; Base Sepolia has strong faucet and tooling coverage [17]. Do not deploy to both. |
| Web3 client | wagmi + viem | viem now, wagmi later | Hackathon: backend relayer wallet signs transactions; browser uses **viem read-only** to verify independently. Add wagmi only when labs/doctors must sign with their own wallets. |
| Frontend host | Vercel | Keep for demo only | Hobby plan is non-commercial [18]; move to Cloudflare Pages/Netlify or Vercel Pro for a beta. |
| Backend host | Render | Keep for demo only | Free service sleeps and has 512 MB [18]; paid Starter from $7/month avoids both. |
| DB host | Supabase / Neon | Supabase | One vendor for auth, DB, storage cuts glue code. |

## 7.2 Final recommended stack

| Tier | Technology (pinned at project start) | Notes |
|---|---|---|
| Web app | Next.js (App Router), TypeScript, Tailwind CSS, shadcn/ui, Recharts, TanStack Query | Types generated from OpenAPI |
| API | FastAPI, Pydantic v2, SQLAlchemy 2 (async) + Alembic, httpx, cryptography, web3.py or viem-node | Single authorisation layer |
| Worker | FastAPI BackgroundTasks (MVP) then Arq/RQ + Redis | OCR and AI jobs |
| Data | Supabase Postgres + pgvector, Supabase Storage (encrypted blobs) | RLS on, service role only in API |
| AI | pdfplumber/pypdfium2, PaddleOCR, Gemini Flash (demo) or Gemma 4 (real), Medical Data Toolkit (FHIR) | Schema-constrained JSON output |
| Chain | Solidity ^0.8.x, Hardhat 3, OpenZeppelin, viem; Polygon Amoy or Base Sepolia | Contract ~40 lines |
| Ops | GitHub Actions, Sentry free, Better Stack/UptimeRobot free ping | Keepalive for Supabase |

**RECOMMENDATION**

**Complexity budget.** Count moving parts for the hackathon: 1 frontend, 1 API, 1 managed Postgres/Storage/Auth, 1 contract, 1 LLM API. That is five. Every extra service (Redis, Celery, separate vector DB, IPFS, wagmi wallet UX) costs hours you do not have.

SECTION 8

# Product requirements document (PRD)

## 8.1 Problem statement

Healthcare information is fragmented across hospitals, labs, clinics and phones. Patients lack a unified history and struggle to understand reports; clinicians lack historical context; documents cannot easily be verified; patients cannot see who accessed their data. Evidence in Section 5 shows storage and AI summaries are being commoditised, so this PRD prioritises **verifiability, patient-readable access control and clinician-ready synthesis**.

## 8.2 Personas

| Persona | Profile | Top needs | Pain today |
|---|---|---|---|
| **Asha, patient** | 44, type-2 diabetes, reports from 3 labs over 6 years, Android phone, Hindi/English | See HbA1c trend, understand a new report, share only the right records, know who looked | Photos of paper reports; cannot explain history in 8-minute consults |
| **Dr. Rao, GP/endocrinologist** | Private clinic, sees 40 patients/day, uses a basic EMR | One-page summary with deltas before consult; confidence a report is genuine; issue a signed prescription | Patients arrive with loose papers; cannot check authenticity |
| **City Diagnostics, lab** | Mid-size lab, LIS exports PDFs | Deliver verifiable reports, reduce "is this report real?" calls, audit of issued reports | Reports forwarded as unverifiable PDFs |
| **Admin, platform ops** | Trust & safety / support lead | Verify institutions, review suspicious access, handle breach workflow | No unified view of access anomalies |

## 8.3 User journeys (summary)

- **Patient:** sign up → upload report → review extracted values, confirm flagged ones → read summary → see trend after second report → invite doctor with 7-day expiry → see access log → revoke.
- **Doctor:** receive link/OTP → view authorised patient summary → open source report → click Verify (hash recomputed in browser, chain checked) → compare two reports → issue signed prescription.
- **Lab:** onboard and get verified → upload report against patient ID/phone → report is signed and anchored → patient accepts → lab sees issuance audit.
- **Emergency (post-MVP):** clinician with verified HPR identity requests break-glass → reason + 30-min scoped access → patient and contact notified instantly → admin reviews.

## 8.4 Feature prioritisation

Scores 1-5 (5 = best). Complexity and time are inverted so a higher score means easier/shorter. **[ESTIMATE]**

| Feature | User value | Ease | Dev speed | Demo power | Long-term viability | Total /25 | Decision |
|---|---|---|---|---|---|---|---|
| F1 Unified records (upload, library) | 5 | 4 | 4 | 3 | 4 | 20 | MVP |
| F2 AI document intelligence | 5 | 3 | 3 | 5 | 3 | 19 | MVP (core) |
| F3 Longitudinal analytics | 5 | 4 | 4 | 5 | 5 | 23 | MVP |
| F4 AI assistant (RAG) | 4 | 3 | 3 | 4 | 3 | 17 | MVP-lite (one grounded Q&A;) |
| F5 Blockchain verification | 3 | 4 | 4 | 5 | 3 | 19 | MVP (core) |
| F6 Access management | 5 | 3 | 3 | 4 | 5 | 20 | MVP (off-chain) |
| F7 Emergency access | 4 | 1 | 1 | 3 | 4 | 13 | Post-MVP; simulate |
| F8 Verifiable prescriptions | 4 | 2 | 2 | 4 | 5 | 17 | Phase 2; simulate in demo |

## 8.5 Functional requirements

| ID | Requirement | Pri | Phase |
|---|---|---|---|
| FR-01 | Users register and sign in with email OTP; role is patient, doctor, lab or admin | P0 | MVP |
| FR-02 | Patient uploads PDF/JPG/PNG up to 15 MB; file is encrypted before storage | P0 | MVP |
| FR-03 | System extracts text (PDF layer, else OCR/vision), returns structured analytes {name, value, unit, ref range, flag, page, bbox} | P0 | MVP |
| FR-04 | Patient can edit/confirm any extracted value; edited values are marked "user-corrected" | P0 | MVP |
| FR-05 | System generates plain-language summary with abnormal values highlighted and a non-diagnostic disclaimer | P0 | MVP |
| FR-06 | Analyte series are normalised and charted over time; ranges configurable per lab/patient | P0 | MVP |
| FR-07 | Report-to-report comparison with deltas and direction | P0 | MVP |
| FR-08 | Document fingerprint registered on testnet; transaction reference stored | P0 | MVP |
| FR-09 | Verification recomputes hash from the retrieved file and compares with chain; shows result, network, tx, timestamp | P0 | MVP |
| FR-10 | Patient grants doctor access to selected records with expiry; revoke is immediate | P0 | MVP |
| FR-11 | Every read of a patient record writes an audit event visible to the patient | P0 | MVP |
| FR-12 | AI assistant answers only from the requesting user's authorised records and cites sources | P1 | MVP-lite |
| FR-13 | Lab portal issues signed reports to a patient | P1 | Phase 2 |
| FR-14 | Doctor issues digitally signed prescription with QR verification | P1 | Phase 2 |
| FR-15 | Break-glass emergency access with notifications and review | P2 | Phase 3 |
| FR-16 | ABHA login (M1) and consent-based record fetch (M3) | P1 | Phase 2 |
| FR-17 | Data export and account deletion (crypto-shred) | P1 | Phase 2 |
| FR-18 | Consent Manager-compatible consent records and withdrawal | P1 | Phase 2 |

## 8.6 Non-functional requirements

| Area | Requirement |
|---|---|
| Security | TLS 1.2+; AES-256-GCM per-file encryption; no PHI in logs; secrets in env/KMS; OWASP ASVS L2 target |
| Privacy / compliance | DPDP-ready consent notices, one-year log retention, 72-hour breach reporting runbook (Section 14) |
| Performance | Dashboard p95 < 2 s; upload-to-summary p50 < 45 s (MVP) |
| Reliability | MVP: best effort. Beta: 99.5%, daily backups, tested restore |
| Accessibility | WCAG 2.2 AA; keyboard operable; no colour-only status |
| Localisation | English first; Hindi next; layout ready for Indic scripts |
| Auditability | Append-only audit table; periodic Merkle root anchored on-chain |
| Maintainability | Typed end to end; migrations; CI runs unit, API and contract tests |

## 8.7 User stories and acceptance criteria

| Story | Acceptance criteria |
|---|---|
| As a patient I upload a blood report so I can see my values. | 1) PDF accepted ≤ 15 MB. 2) Within 60 s analytes appear with units. 3) Each value links to its source region. 4) Unreadable file yields a clear error and no partial save. |
| As a patient I correct a wrongly read value. | 1) Edit saves immediately. 2) Original extracted value retained in history. 3) Chart updates. |
| As a patient I compare two reports. | 1) Select two dates. 2) Table shows each shared analyte, delta and direction. 3) Different units are converted or flagged, never silently mixed. |
| As a patient I share with Dr. Rao for 7 days. | 1) Choose records. 2) Doctor sees only those. 3) After expiry or revoke, API returns 403 within 2 s. 4) Log shows each view. |
| As a doctor I verify a report. | 1) Verify button recomputes SHA-256 in browser. 2) Match shows green "Unmodified since [time]" with tx link. 3) Altered file shows red mismatch. |
| As a patient I ask "what changed since January?" | 1) Answer cites report IDs and dates. 2) Declines diagnosis or dosing. 3) Never references records outside my authorisation. |

## 8.8 MVP definition vs product vision

| Hackathon MVP (24-48 h) | Beta (months 1-6) | Full vision (months 6-15) |
|---|---|---|
| Patient and doctor roles; upload; extraction on synthetic reports; summary; trends; compare; hash registration and verification; grant/revoke with audit log; simple grounded Q&A; | Lab issuance with signatures; real encryption keys via KMS; ABHA M1; DPDP consent records; backups; paid hosting; VAPT; localisation | M2/M3; signed prescriptions; emergency access; batching and Merkle anchoring; insurer verification API; mobile app |

## 8.9 Dependencies, risks and assumptions

| Item | Type | Detail / mitigation |
|---|---|---|
| ABDM sandbox access and certification | Dependency | Needs HFR/HPR registration, bridge, security audit; any 2 milestones to exit sandbox per NHA support [13] |
| Lab cooperation | Dependency | Pilot with one friendly lab before building portal |
| Incorrect extraction harms users | Risk (high) | Human confirm step; never auto-flag diagnosis; accuracy dashboard |
| Incumbents free and state-backed | Risk (high) | Validate wedge; pivot to B2B verification if needed |
| Regulatory non-compliance | Risk (high) | Legal review before real data; DPDP checklist |
| Free-tier instability | Risk (medium) | Abstract providers; keepalive; demo rehearsal |
| Users accept hash-only guarantee as "authenticity" | Risk (medium) | Label clearly: integrity since registration, not origin, unless signed by issuer |
| Assumption: ₹90 per USD | Assumption | Used for conversions; re-check |
| Assumption: solo developer, 15-20 productive hours/week outside hackathon | Assumption | Drives roadmap durations |

## 8.10 Success metrics

| Stage | Metric | Target |
|---|---|---|
| Hackathon | End-to-end demo with no manual intervention | 3 consecutive rehearsals |
| Hackathon | Judge-visible tamper test (edit one byte, verification fails) | Works live |
| Beta | Activation (first report uploaded within 24 h) | ≥ 60% |
| Beta | Extraction field accuracy on gold set | ≥ 95% printed, ≥ 85% photos |
| Beta | Doctors who verify at least one report | ≥ 30% of invited |
| Beta | Median grant-to-first-view time | < 1 day |

SECTION 9

# UI/UX design specification

**Design intent.** A calm, serious clinical instrument, not a startup dashboard. Warm paper backgrounds, dense but legible tables, restrained colour that is reserved for meaning (verified, abnormal, caution). The memorable element is the **seal motif**: every verified document carries a small round seal with its status, consistently across lists, detail views and doctor summaries.

## 9.1 Visual identity

| Token | HEX | Use |
|---|---|---|
| Ink | #10222E | Primary text, navigation rail |
| Paper | #F6F4EE | App background (warm, reduces glare vs pure white) |
| Surface | #FFFFFF | Cards, tables |
| Verdigris | #1F7A6D | Primary actions, healthy/in-range, verified |
| Verdigris Deep | #14584F | Headings, pressed states |
| Sage | #DDE8E2 | Verified surface, in-range bands on charts |
| Seal Blue | #2B5FA8 | AI-generated content, informational |
| Seal Blue Tint | #E3ECF8 | AI insight panels |
| Amber | #B7791F | Caution, not-yet-registered, low confidence (fill/icon; use darker text on tints) |
| Vermilion | #B4421C | Out-of-range, mismatch, destructive |
| Slate | #5B6B76 | Secondary text |
| Rule | #D5D9D6 | Borders and dividers |

[RECOMMENDATION] **Typography.** Headings: *Source Serif 4* or *Fraunces* (semibold) for gravity. Body and UI: *IBM Plex Sans*. Numbers and hashes: *IBM Plex Mono* with tabular figures. All are free Google Fonts. Scale: 12/14/16/20/28/40 px; body 15 px; table text 13 px.

[RECOMMENDATION] **Components.** shadcn/ui primitives re-themed with the tokens above; Recharts for trends; a custom *SealBadge* (verified / unregistered / mismatch / issuer-signed) and *RangeBar* (value on a range track) as signature components.

**Layout and navigation.** 12-column grid, 8 px spacing unit. Desktop: left rail (72 px collapsed, 232 px expanded) with Overview, Records, Analysis, Assistant, Access, Verify. Mobile: bottom tab bar with five items and a floating Upload action. Doctor app uses a patient-list left panel and tabbed patient workspace.

**Responsive behaviour.** Breakpoints 360, 768, 1100, 1440. Tables collapse to stacked rows below 768; charts keep a minimum 220 px height; source-document viewer becomes a full-screen sheet on mobile.

**Accessibility.** WCAG 2.2 AA; contrast checked for every token pair (Amber is never used as text on white); abnormal values use icon + text + colour; focus rings 2 px Seal Blue; charts have a data-table toggle; reduced-motion respected; language switcher for English and Hindi first.

**Interaction patterns.** Uploads show a staged progress rail (Encrypting → Reading → Structuring → Summarising → Registering). Low-confidence values are pre-flagged and block "Save" until confirmed. Destructive actions (revoke, delete) use a confirm sheet describing consequences. Every AI output carries a Seal Blue label and source chips.

## 9.2 Screen specifications

### Patient dashboard

**Purpose:** Health overview; recent reports; metrics; AI insights; verification status; access permissions.

**Wireframe description:** Top: greeting and global search. Row 1: four KPI tiles (latest value, delta, range status). Row 2: trend chart (selectable analyte) beside AI insight panel. Row 3: recent reports list with seal badges beside access summary and primary Upload action.

**Components:** KPITile, TrendChart, InsightPanel, ReportRow, SealBadge, AccessSummary, UploadButton

### Medical records

**Purpose:** Document library; upload workflow; categories; search and filters; verification status.

**Wireframe description:** Left filter column (type, lab, date, verified state). Main grid/table of documents with thumbnail, title, date, source, seal, status. Upload opens a 3-step dialog: choose file → category/date/lab → review extraction.

**Components:** FilterPanel, DocTable, UploadDialog, CategoryChips, SealBadge, EmptyState

### AI health analysis

**Purpose:** Report summaries; extracted parameters; historical comparison; abnormal indicators; explanations.

**Wireframe description:** Split view: source viewer (left) with highlight boxes; parameters table (right) with RangeBar and flag; summary card; compare drawer selects a second report and shows deltas.

**Components:** DocViewer, ParamTable, RangeBar, SummaryCard, CompareDrawer, ConfidenceChip

### AI assistant

**Purpose:** Chat; context selection; sources; suggested questions.

**Wireframe description:** Left: context selector (all records / chosen reports / date range). Centre: chat with message-level source chips. Right (desktop): cited sources preview. Footer: guardrail note and "Prepare doctor questions" shortcut.

**Components:** ContextPicker, ChatThread, SourceChip, SuggestedQuestions, GuardrailBanner

### Access management

**Purpose:** Connected doctors; permissions; expiry; access logs; revocation.

**Wireframe description:** Tabs: People · Pending requests · Activity log. Each person card shows scope, expiry countdown, last view, Revoke. Grant dialog: pick doctor, tick records, choose 24 h/7 d/30 d/custom. Log is a filterable timeline with plain-language reasons.

**Components:** PersonCard, GrantDialog, ScopeTree, ExpiryPicker, ActivityTimeline, RevokeSheet

### Doctor dashboard

**Purpose:** Authorised patients; summaries; diagnostic history; comparisons; prescriptions.

**Wireframe description:** Left: patient list with consent expiry. Workspace tabs: Summary (one-page trend sheet) · Reports · Compare · Prescriptions. Header always shows access basis and expiry. Print/PDF one-pager.

**Components:** PatientList, SummarySheet, ReportList, CompareView, RxComposer, AccessBanner

### Blockchain verification

**Purpose:** Hash; network; transaction; result; timestamp.

**Wireframe description:** Large result banner (verified / not registered / mismatch). Below: key-value list (fingerprint, network, contract, transaction link, block time, issuer signature). Actions: verify another file, copy verification link. Plain-language explanation of what the result does and does not prove.

**Components:** ResultBanner, KeyValueList, HashField, ExplorerLink, ExplainerPanel

# 9.3 Wireframes (key screens)

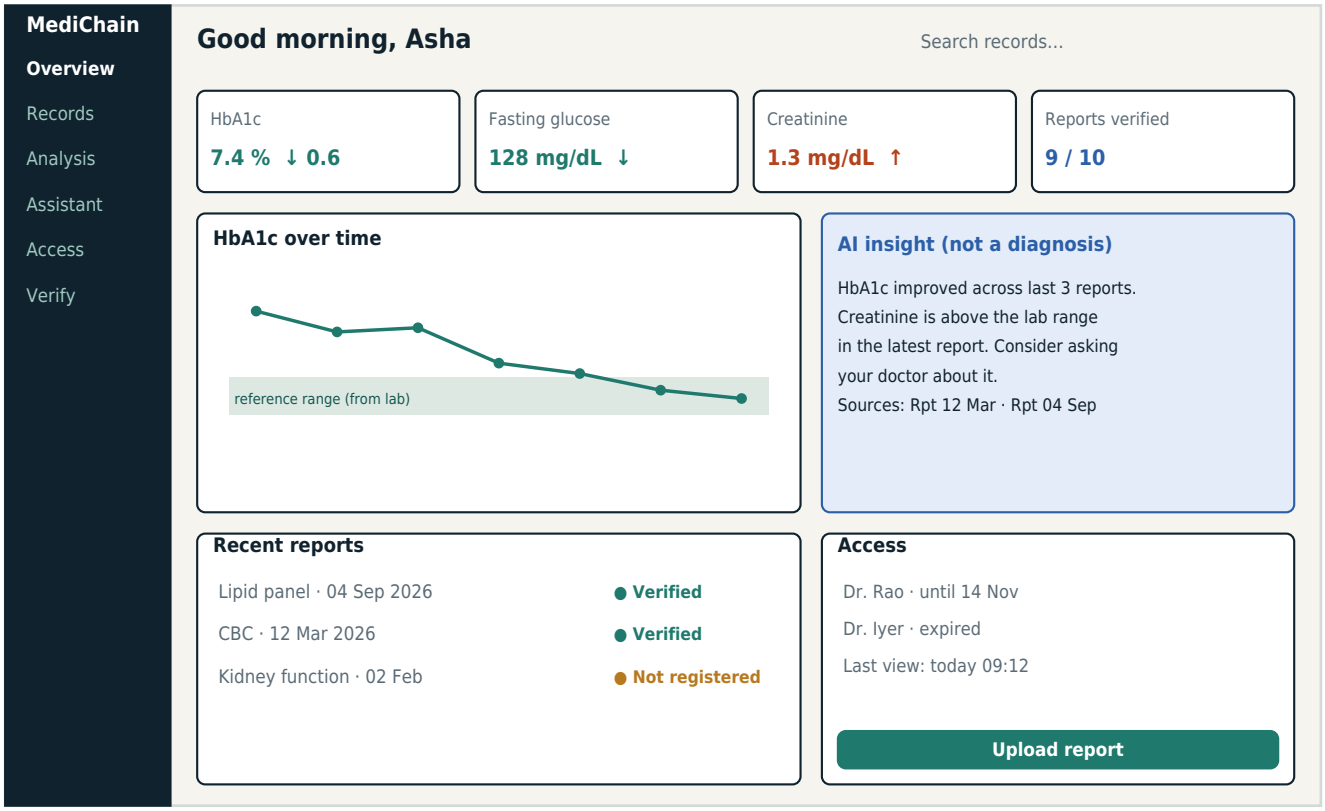



*Figure 1. Patient dashboard wireframe (illustrative values, synthetic).*

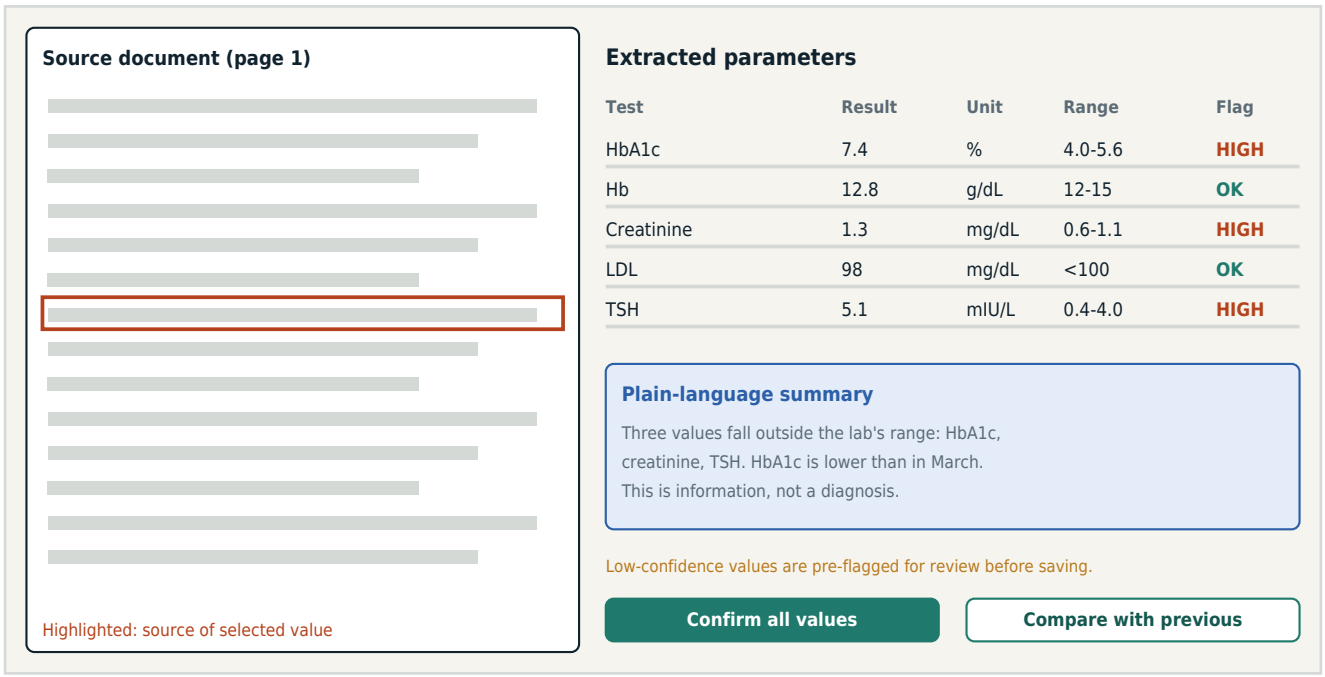



*Figure 2. AI health analysis: source document beside extracted parameters, with confirmation before save.*

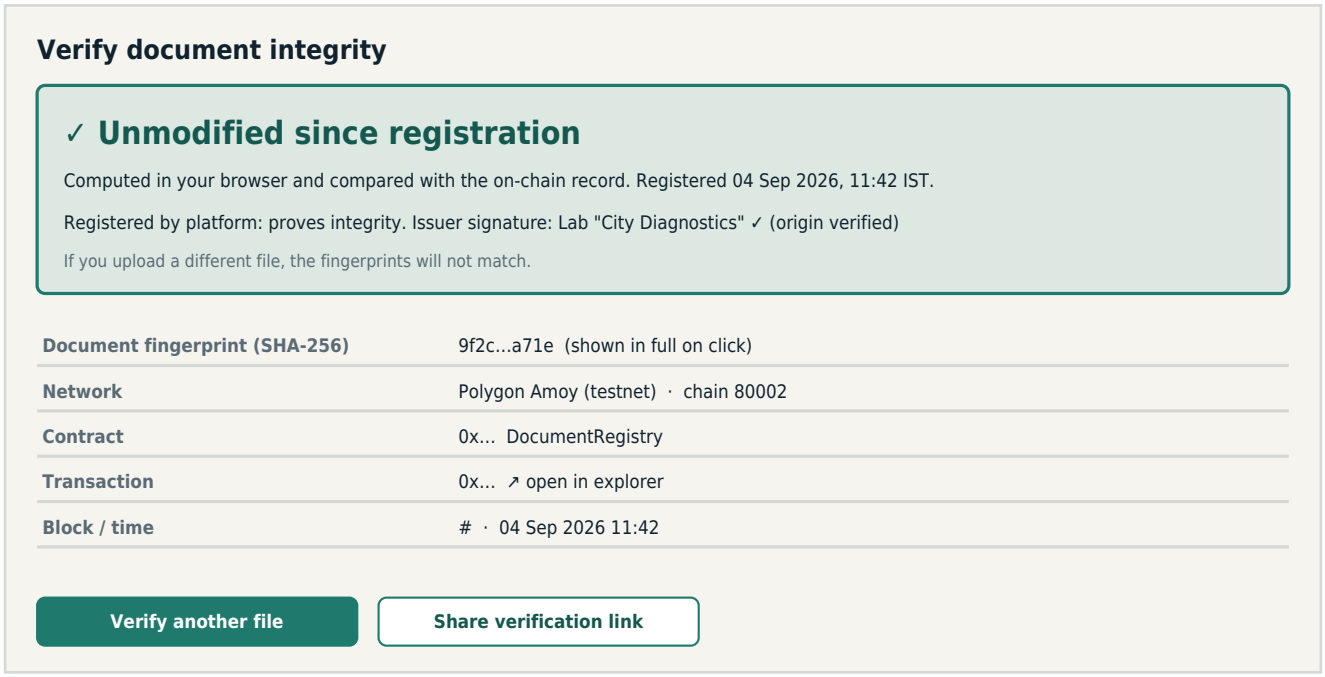



*Figure 3. Blockchain verification result with explicit statement of what is and is not proven.*

SECTION 10

# Technical architecture

## 10.1 System architecture

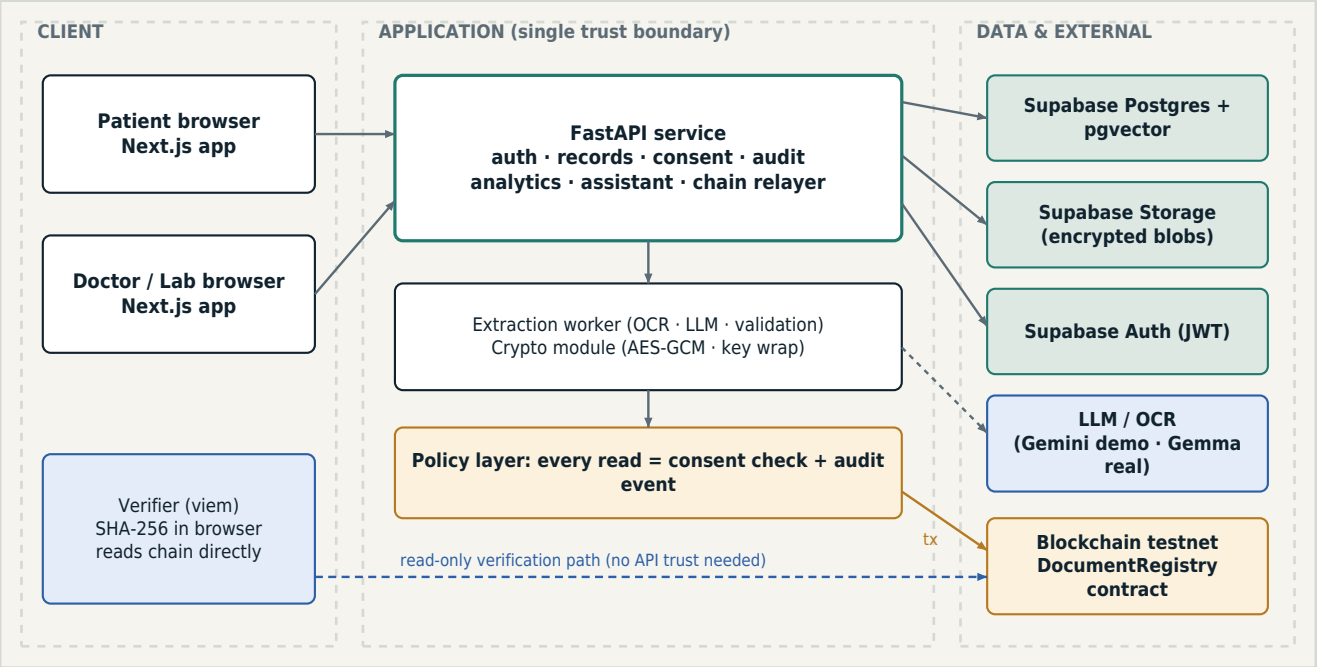



*Figure 4. System architecture. FastAPI is the only component that touches the database, keys, or chain-signing wallet.*

**Principles.** (1) All data access passes the policy layer: consent check, then audit write, then data. (2) The browser never holds the master keys or the relayer wallet. (3) The chain only ever sees a salted commitment, never identity or content. (4) The verification path reads the chain directly so MediChain cannot forge a "verified" badge.

## 10.2 Frontend architecture

- Next.js App Router: server components for lists and dashboards; client components for upload, charts and the verifier. Route groups: `(auth)`, `(patient)`, `(doctor)`, `(lab)`, `(admin)`.
- Data layer: TanStack Query against a typed client generated from FastAPI's OpenAPI (e.g. openapi-typescript). No direct database access from Next.js.
- Auth: Supabase Auth session; access token sent as Bearer; middleware redirects by role.
- Verifier module: Web Crypto SHA-256, viem public client for chain reads; no secrets.
- Folder sketch: `app/ · components/(ui, seal, charts) · lib/(api, verify, format) · hooks/ · styles/tokens.css`.

## 10.3 Backend architecture (FastAPI)

```
backend/
  app/
    main.py                # app factory, CORS, middleware, error handlers
    core/ config.py security.py crypto.py policy.py logging.py
    db/   session.py models/ (SQLAlchemy) alembic/
    modules/
      auth/ users/ records/ extraction/ analytics/
      consent/ audit/ chain/ assistant/ prescriptions/ admin/
      (each: router.py service.py repo.py schemas.py)
    workers/ extract.py summarise.py embed.py anchor.py
  tests/ unit/ api/ contract/ eval/ (extraction gold set)
```

Layering: router (HTTP, validation) → service (rules, transactions) → repository (queries). Authorisation is expressed once in `policy.py` (`can_read(actor, document)`) and used by every service. Background work uses FastAPI

BackgroundTasks in the MVP and Arq/RQ with Redis once volume or retries demand it.

## 10.4 Encryption and file storage architecture

| Item | Design |
|---|---|
| At rest (file) | Per-file random 256-bit DEK; AES-256-GCM; ciphertext stored in a private bucket; DEK wrapped with a KEK and stored in `documents.enc_dek` |
| KEK | MVP: environment secret (rotatable, documented). Production: managed KMS in an Indian region (e.g. AWS KMS Mumbai) with per-patient KEKs so deleting a patient KEK crypto-shreds all their files |
| In transit | TLS everywhere; HSTS; signed short-lived download URLs are **not** used for plaintext; API streams decrypted bytes after the policy check |
| Database | Provider encryption at rest plus application encryption for salt and any free-text PHI fields you choose to protect |
| Backups | Encrypted; restore drill quarterly; backup retention set to meet one-year log retention [3] |
| Logs | No PHI, no file names with identities; user IDs only |

## 10.5 Answers to the ten architectural questions

| # | Question | Answer and implementation |
|---|---|---|
| 1 | Encrypt files before storage? | **Yes.** Application-level envelope encryption as above. Provider-side encryption alone does not protect against a compromised storage credential or insider. |
| 2 | How are hashes generated and verified? | SHA-256 of the original file bytes, computed client-side and recomputed server-side. Commitment = keccak256(sha256 ‖ 32-byte random salt). Verification recomputes from the retrieved plaintext in the verifier's browser and compares with the chain value (Figure 8). |
| 3 | What is stored on-chain? | Only: commitment (bytes32), registrar address, block timestamp, and periodic Merkle roots of the audit log. No names, IDs, document types, or ciphertext. |
| 4 | Smart contracts or backend for permissions? | **Backend (off-chain).** The server holds the decryption path, so on-chain permissions it could ignore add cost without protection. Anchor audit-log roots on-chain to make tampering with history detectable. |
| 5 | Avoid unnecessary transactions? | Register on patient confirmation only; never per read, grant, or revoke. Production: batch commitments into a Merkle root per hour/day; per-document proofs stored off-chain. |
| 6 | How does AI see only authorised records? | Retrieval functions take the actor and pass through `policy.py`; SQL and vector queries include `patient_id` and consent predicates; the LLM receives only the retrieved context; no tool can query other patients (Section 12). |
| 7 | Extraction and validation? | Schema-constrained JSON, unit normalisation, plausibility bounds, LOINC mapping, per-value confidence, human confirmation (Section 12). |
| 8 | Incorrect OCR or AI output? | Source highlighting, confidence flags, mandatory confirmation for out-of-range values, retained originals for corrections, gold-set regression tests, easy "report a mistake". |
| 9 | Preventing unauthorised access? | Central policy check, RLS defence in depth, short-lived tokens, rate limits, anomaly alerts, MFA for doctors/admins, envelope encryption, audit anchoring. |
| 10 | How do doctors verify authenticity? | Two separate claims. **Integrity**: hash matches chain (unchanged since registration). **Origin**: issuer's digital signature (EIP-712) verifies against a registry of verified labs/doctors. A patient-uploaded file only gets the first claim, labelled honestly. |

SECTION 11

# Database and API specifications

## 11.1 Entity relationship diagram

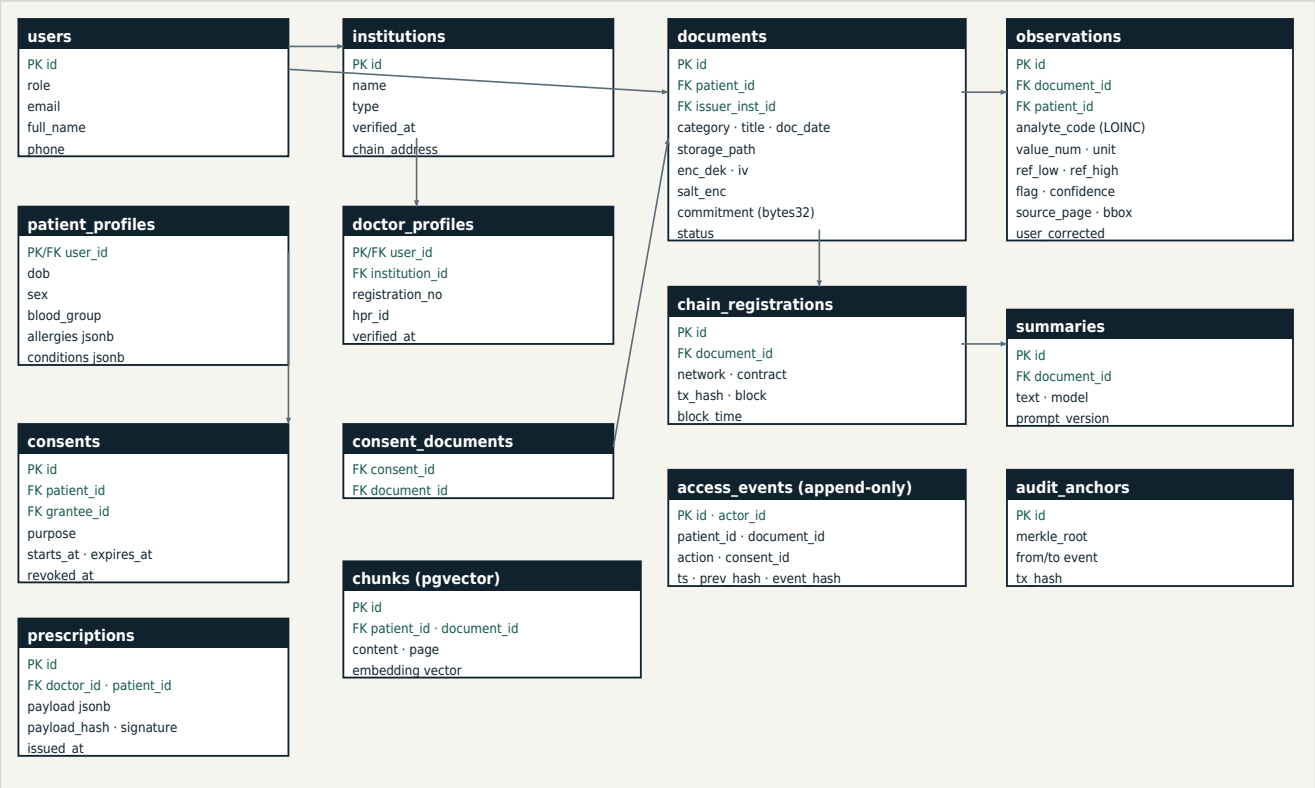



*Figure 5. Core entities and relationships (simplified; indexes and join tables abbreviated).*

## 11.2 Key design notes

- **Observations are the analytic spine.** Index `(patient_id, analyte_code, observed_at)`. Keep both `original_value` and corrected value.
- **Access events are append-only** and hash-chained: `event_hash = sha256(prev_hash || canonical(event))`. Revoke UPDATE/DELETE privileges on the table; a nightly job anchors a Merkle root.
- **Row-level security** on every patient-scoped table as defence in depth: patient sees own rows; doctors see rows only through active consents.
- **Migrations** via Alembic only; schema is defined once in SQLAlchemy models.
- **FHIR:** keep a `fhir jsonb` column on observations/documents for ABDM-bound exports (Phase 2) rather than redesigning later.

## 11.3 Core SQL (excerpt)

```
create table documents (
  id uuid primary key default gen_random_uuid(),
  patient_id uuid not null references users(id),
  issuer_institution_id uuid references institutions(id),
  category text not null, title text not null, doc_date date,
  storage_path text not null, mime text not null, size_bytes int not null,
  enc_dek bytea not null, enc_iv bytea not null, salt_enc bytea not null,
  commitment bytea, status text not null default 'processing',
  created_at timestamptz not null default now());

create table consents (
  id uuid primary key default gen_random_uuid(),
  patient_id uuid not null references users(id),
  grantee_id uuid not null references users(id),
  purpose text not null, starts_at timestamptz not null default now(),
  expires_at timestamptz not null, revoked_at timestamptz);
create index on consents (grantee_id, patient_id) where revoked_at is null;

create table access_events (
  id bigserial primary key, ts timestamptz not null default now(),
  actor_id uuid not null, patient_id uuid not null, document_id uuid,
  action text not null, consent_id uuid, prev_hash bytea, event_hash bytea not null);
```

## 11.4 API specification (REST, JSON, OpenAPI)

Conventions: base path `/api/v1`; Bearer JWT; errors as `{"error":{"code","message","request_id"}}`; cursor pagination; `Idempotency-Key` on uploads and chain writes; rate limit 60 req/min per user (10 for auth and AI endpoints).

| Method | Path | Role | Purpose |
|---|---|---|---|
| POST | /auth/session/exchange | any | Validate Supabase JWT, return profile and role |
| GET/PATCH | /me | any | Profile |
| POST | /documents | patient, lab | Create document + upload (multipart); returns id, status=processing |
| GET | /documents | patient | List with filters (category, date, verified) |
| GET | /documents/{id} | patient, consented doctor | Metadata; writes audit event |
| GET | /documents/{id}/file | patient, consented doctor | Decrypted stream; policy + audit; returns salt in header X-Doc-Salt for verifier |
| GET | /documents/{id}/extraction | patient, consented doctor | Observations, confidence, summary |
| PATCH | /observations/{id} | patient | Correct a value; stores original |
| POST | /documents/{id}/confirm | patient | Confirm extraction; triggers chain registration |
| GET | /documents/{id}/verification | patient, doctor | Stored commitment, tx, block time (verifier still reads chain itself) |
| GET | /analytics/series | patient, consented doctor | ?analyte=&from;=&to;= → time series with ranges |
| GET | /analytics/compare | patient, consented doctor | ?a=&b;= → deltas |
| POST | /assistant/query | patient, consented doctor | {question, context_ids[]} → answer + citations |
| POST | /consents | patient | Grant: grantee, document_ids[], expires_at, purpose |
| DELETE | /consents/{id} | patient | Revoke (immediate) |
| GET | /consents | patient, doctor | List active/expired |
| GET | /access-log | patient | Filterable timeline of access events |

| Method | Path | Role | Purpose |
|---|---|---|---|
| GET | /doctor/patients | doctor | Patients with active consent |
| GET | /doctor/patients/{id}/summary | doctor | One-page trend summary (JSON; PDF export) |
| POST | /lab/documents | lab | Issue signed report to patient (Phase 2) |
| POST | /prescriptions | doctor | Create, sign, anchor (Phase 2) |
| GET | /prescriptions/{id}/verify | public with token | QR verification |
| POST | /emergency/requests | verified clinician | Break-glass request (Phase 3) |
| GET | /admin/events | admin | Anomalies, institution approval |

## 11.5 Authentication and role-based access

| Role | Can | Cannot |
|---|---|---|
| patient | Everything on own data; grant/revoke; export | See other patients |
| doctor | Read only consented documents until expiry; issue prescriptions; request emergency access | Read anything outside consent; delete patient data |
| lab | Issue documents to patients; view own issuance audit | Read patient records after issuing unless patient grants |
| admin | Verify institutions; view anomaly queue; no PHI content access by default | Open document files (break-glass with dual approval only) |

## 11.6 Error handling and testing

Error taxonomy: 400 validation, 401 auth, 403 policy (never reveal existence), 404, 409 conflict, 422 extraction failure, 429 rate limit, 502 provider/chain failure. Chain writes are retried with backoff and a "pending" state that never blocks the user. Tests: unit (policy, crypto, normalisation), API (consent matrix: every role × every endpoint), contract tests (Hardhat), extraction regression on a 50-report gold set, and a nightly E2E (Playwright) for the demo path.

SECTION 12

# AI/ML implementation strategy

**Principle.** AI is used only where it has a defined job: (a) read a document, (b) structure it, (c) explain validated numbers in plain language, (d) answer questions grounded in the patient's own records. It never diagnoses, prescribes, or sees data the actor is not authorised to see.

## 12.1 Document intelligence pipeline

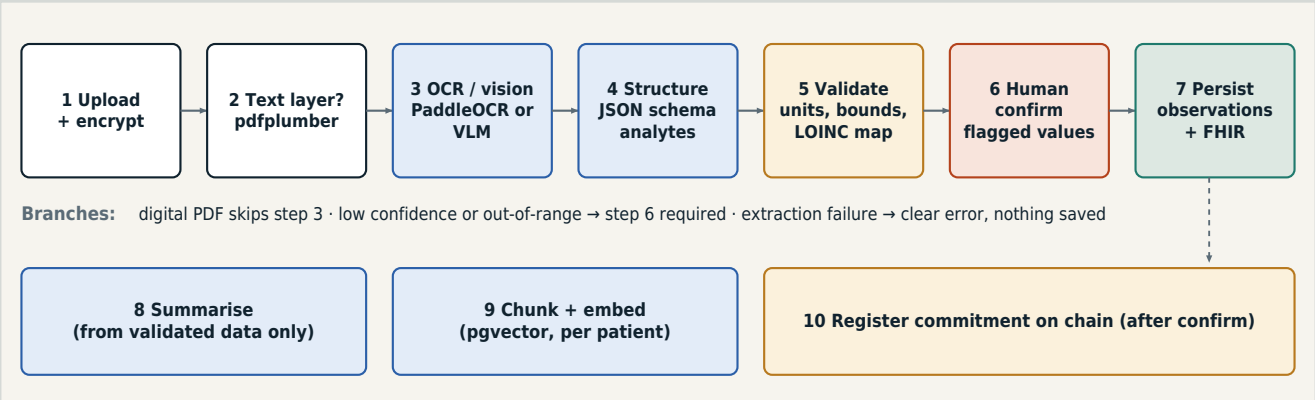



*Figure 6. Extraction pipeline. Ten stages; the confirmation gate is what makes the system safe to use.*

| Stage | Implementation | Notes |
|---|---|---|
| Text layer first | pypdfium2/pdfplumber; if text length above a threshold, skip OCR | Exact and free; most lab PDFs are digital |
| OCR or vision | PaddleOCR (PP-OCRv5/v6) for self-hosted; vision-LLM for the demo and for photos. Pre-process: deskew, denoise, upscale to ~300 dpi | Study evidence: neural OCR beat Tesseract on noisy Indian reports and compact multimodal models beat both [19] |
| Structuring | LLM call with a JSON schema (below); temperature 0; one retry on schema failure; temperature stays 0 | Never let the model invent a unit or range; copy from the page |
| Validation | Unit whitelist per analyte; plausibility bounds (e.g. HbA1c 2-20 %); numeric parse; duplicate detection; LOINC mapping via a curated table of ~60 common analytes | Unknown analytes are kept as text, never dropped |
| Confidence | Per value: OCR confidence × model self-check × validation result. Below 0.85 or out of range → needs confirm | Thresholds tuned on the gold set |
| Persistence | Observations with source page and bounding box; FHIR Observation JSON optional via Google Medical Data Toolkit [8] | Original value retained when corrected |

```
// extraction schema (excerpt)
{ "report": {"lab_name": str, "report_date": "YYYY-MM-DD", "patient_name_present": bool},
  "observations": [{
      "name": str, "value": number|null, "value_text": str|null,
      "unit": str|null, "ref_low": number|null, "ref_high": number|null,
      "lab_flag": "H"|"L"|"N"|null, "page": int, "bbox": [x0,y0,x1,y1] }] }
```

## 12.2 Reference ranges and abnormal values

- **Lab range wins.** Store the range printed on that report; flag from it. Different labs and methods differ, so a global range would mislabel values.
- **Configurable fallback.** A `reference_ranges` table keyed by analyte, sex, age band and method supplies defaults only when the report has none; the UI says "default range" when used.
- **Never silently mix units.** Convert only through a tested conversion table (e.g. glucose mg/dL ↔ mmol/L); otherwise show both series separately.
- **Trends use patient context.** Delta direction is described (higher/lower), not judged as good/bad, except where the report itself flags it.

## 12.3 Handling incorrect OCR or AI interpretations

| Failure mode | Control |
|---|---|
| Digit misread (e.g. 7.4 read as 74) | Plausibility bounds; decimal-place check vs previous values; forced confirmation |
| Unit misread or missing | Unit whitelist; flag and require selection |
| Hallucinated analyte | Every observation must have a source bbox that contains the value text; otherwise dropped |
| Wrong patient's report | Name/ID presence check vs profile (warn, do not store name in AI logs) |
| Summary overstates meaning | Summary generated only from validated observations; fixed template of allowed statements; non-diagnostic disclaimer |
| Model or prompt regression | Gold-set evaluation in CI; fail build if field accuracy drops |

## 12.4 Retrieval-augmented assistant (RAG)

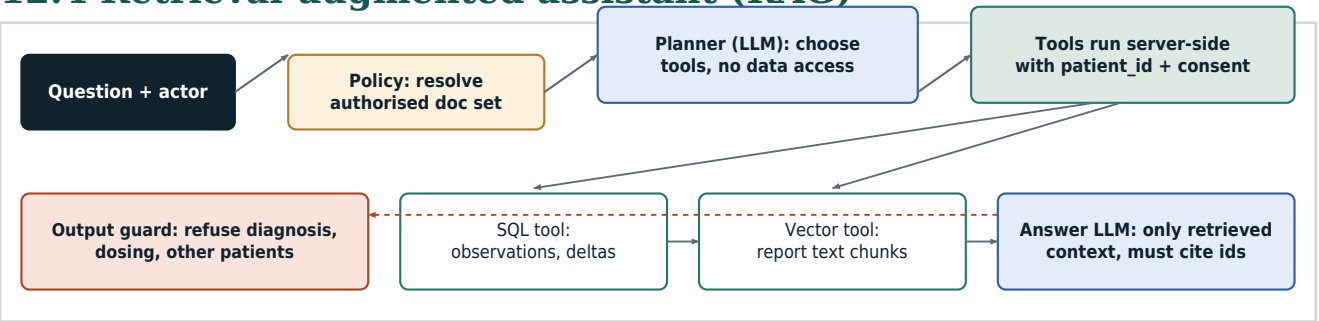



*Figure 7. Authorised retrieval. The planner never touches data; tools enforce patient and consent filters.*

- **Structured retrieval first.** Numeric questions ("what changed in my creatinine?") are answered by SQL over `observations`, not by embeddings: exact and auditable.
- **Vector retrieval second.** Narrative text (impressions, doctor notes) chunked 300-500 tokens with page metadata into pgvector; embedding via a free-tier model for synthetic demo or a local model for real data.
- **Authorisation is inside the query.** The tool takes the authenticated actor and consent-resolved document IDs from `policy.py`; the model cannot supply a patient ID.
- **Answer contract.** Cite document IDs and dates; say "not found in your records" when evidence is absent; refuse diagnosis, dosing, drug changes, or emergency triage (direct to a clinician or emergency services).
- **Prompt-injection defence.** Document text is untrusted: delimited as data, instructions inside it ignored, outputs scanned for other patient identifiers.
- **Evaluation.** 30 adversarial prompts (cross-patient requests, dosing, "ignore instructions") must all be refused or safely answered before release.

## 12.5 Model strategy and gold set

| Stage | Hackathon (synthetic data only) | Real data |
|---|---|---|
| Extraction | Gemini Flash-class via free tier [15] | Gemma 4 (self-hosted) or paid zero-retention API; PaddleOCR; Medical Data Toolkit for FHIR [8] |
| Summaries / chat | Gemini Flash-class | Same model family as extraction, privately hosted |
| Embeddings | Free-tier embedding model [15] | Local sentence-transformers |
| Evaluation | 10 synthetic reports | 50-report gold set with field-level labels; track accuracy per analyte |

**RECOMMENDATION**

**Build the gold set early.** Generate synthetic reports (varied layouts, fonts, scan quality, Hindi/English mixed headers) with known values. It doubles as the hackathon demo data and as your regression suite, and it never touches real PHI.

SECTION 13

# Blockchain implementation strategy

## 13.1 What goes where

| Data | On-chain | Off-chain | Why |
|---|---|---|---|
| Document file | No | Encrypted in storage | Size, privacy, DPDP erasure |
| Commitment = keccak256(sha256(file) ‖ salt) | **Yes** | Also in DB | Tamper evidence; salt prevents anyone confirming a known file by hashing it |
| Registrar address, timestamp | Yes (event/state) | Mirror in DB | Independent timestamp |
| Issuer identity and signature | Issuer address only | Institution details in DB | Verify origin without exposing patients |
| Consents and revocations | **No** | DB + audit log | Server enforces access; chain cannot |
| Audit-log Merkle root | Yes (periodic) | Full log in DB | Detect silent edits to history |
| Patient identity, names, report type | No | Encrypted DB | Privacy |

## 13.2 Network choice

Use **one** EVM testnet. **[FACT]** Polygon Amoy (chain 80002, POL) is the only Polygon testnet still operated and has multiple faucets; Base Sepolia has Alchemy, QuickNode and Circle faucets [17]. **[RECOMMENDATION]** Choose Polygon Amoy if you intend a Polygon PoS mainnet later (low fees, India developer familiarity **[ASSUMPTION]**), Base Sepolia if you prefer Coinbase's tooling. Do not build on Ethereum Sepolia: one source lists its support window ending 30 September 2026 [17].

## 13.3 Smart contract (reference design)

```
// SPDX-License-Identifier: MIT
pragma solidity ^0.8.24;
import "@openzeppelin/contracts/access/Ownable.sol";

contract DocumentRegistry is Ownable {
    struct Entry { address registrar; uint64 timestamp; }
    mapping(bytes32 => Entry) public entries;      // commitment => entry
    mapping(address => bool) public issuers;       // verified labs/doctors
    event Registered(bytes32 indexed commitment, address indexed registrar, uint64 ts);
    event RootAnchored(bytes32 indexed root, uint64 ts);  // audit-log or batch root
    constructor() Ownable(msg.sender) {}
    function setIssuer(address a, bool ok) external onlyOwner { issuers[a] = ok; }
    function register(bytes32 c) external {
        require(entries[c].timestamp == 0, "exists");
        entries[c] = Entry(msg.sender, uint64(block.timestamp));
        emit Registered(c, msg.sender, uint64(block.timestamp));
    }
    function anchorRoot(bytes32 root) external onlyOwner { emit RootAnchored(root, uint64(block.timestamp))
; }
    function verify(bytes32 c) external view returns (bool ok, address who, uint64 ts) {
        Entry memory e = entries[c]; return (e.timestamp != 0, e.registrar, e.timestamp);
    }
}
```

**[ASSUMPTION]** This is a design sketch for the coding agent, not audited code. Add: pause switch, tests for duplicate/zero commitments, and an EIP-712 `registerSigned(commitment, issuedAt, signature)` variant so a lab or doctor signs and the relayer submits. Keep the contract tiny: every added feature is attack surface.

## 13.4 Interaction flow and verification

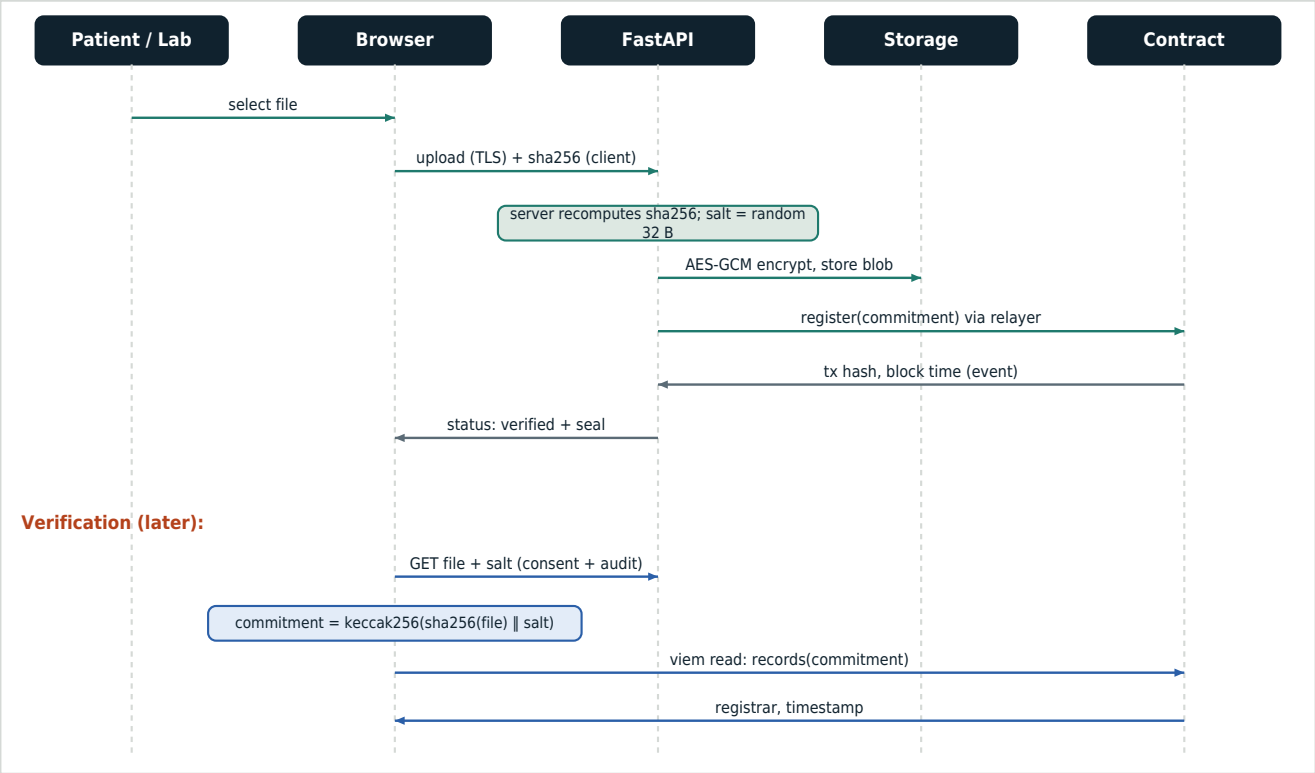



*Figure 8. Registration (top) and verification (bottom). The verifier path reads the chain without trusting the API.*

## 13.5 Avoiding unnecessary transactions

- Register only after the patient confirms extracted values, once per document.
- No transaction for grants, revokes, reads or chat. These live in the audit log.
- Production: queue commitments and anchor a Merkle root each hour/day; store each document's Merkle proof off-chain. Verification then needs the proof plus the root event; cost per document approaches zero.
- Relayer pays gas; the hot key lives in a secrets manager with a daily spend cap and alerting.

## 13.6 Cost and risk notes

| Topic | Detail |
|---|---|
| Testnet cost | Free via faucets [17]. Faucet drips vary by source (about 0.1 to 0.5 POL per day); fund the relayer a day before a demo. |
| Mainnet cost | **[ESTIMATE]** A registration writes one storage slot plus an event, roughly 50,000-80,000 gas. Multiply by the live gas price and token price at launch; measure on testnet first. Batching removes most of it. |
| Key risk | Relayer key theft allows spam registrations (not forged documents, since verification checks the commitment). Mitigate with caps and issuer signatures. |
| Honest claim | The anchor proves a file existed unchanged at time T. It does not prove the file is clinically correct or that the registrar was its true author unless an issuer signature is present. |
| DPDP erasure | Only a salted commitment is on-chain. Deleting the file and salt (crypto-shred) makes the commitment meaningless; no personal data remains on the ledger [3][20]. |
| Reorgs / finality | Wait for adequate confirmations before showing "Registered"; show "pending" meanwhile. |

SECTION 14

# Security and regulatory considerations

**WARNING**

This section summarises research, not legal advice. Engage an Indian health-data lawyer before processing real patient data or launching publicly.

## 14.1 Threat model (top risks)

| Threat | Impact | Controls |
|---|---|---|
| Broken access control (IDOR) | Cross-patient data leak | Central policy function, RLS, consent matrix tests for every endpoint |
| Stolen credentials / session | Account takeover | OTP + MFA for doctors/admins, short JWT, device alerts |
| Storage or DB compromise | Mass PHI exposure | Envelope encryption, KMS, per-patient KEK, least-privilege service roles |
| LLM prompt injection via uploaded PDF | Data exfiltration, false summaries | Untrusted-data delimiting, tool-level authorisation, output scanning |
| Third-party AI data retention | Privacy violation | No real PHI to free tiers [15]; DPA and zero-retention for production |
| Insider misuse | Snooping | Audit hash chain, admin no-PHI default, dual approval |
| Relayer key theft | Spam / cost | Secrets manager, caps, rotation |
| Supply-chain (npm/pip) | Backdoor | Lockfiles, pinned versions, dependency scanning, no wildcard installs |

## 14.2 DPDP Act and Rules: what is mandatory vs recommended

| Topic | Status | What it means for MediChain AI | Class |
|---|---|---|---|
| Rules notified | In force (13 Nov 2025; some outlets report 14 Nov) [1][2] | Data Protection Board provisions already effective | **[FACT]** |
| Consent Manager framework (Rule 4) | Commences 13 Nov 2026 [1] | Applies to entities operating as Consent Managers; fiduciaries relying on consent should be ready to integrate with registered ones. Design consent records to be portable | Mandatory for CMs; plan for others |
| Core obligations (notice, consent, rights, security, breach, retention, children) | Commence 13 May 2027 [1][2] | Build now; assume no grace period | Mandatory from May 2027 |
| Security safeguards (Rule 6) | From May 2027 | Encryption/masking, access controls, activity logs, backups, monitoring [3] | Mandatory |
| Log retention | From May 2027 | Retain relevant logs and personal data at least one year for specified purposes [3]; note conflict with deletion: reconcile in retention policy | Mandatory |
| Breach notification (Rule 7) | From May 2027 | Notify affected individuals without delay; report to the Board immediately and in detail within 72 hours [2][3] | Mandatory |
| Erasure notice | From May 2027 | At least 48 hours notice before erasure in the contexts the Rules specify [2] | Mandatory where applicable |
| Children's data (Rules 10-12, Fourth Schedule) | From May 2027 | Verifiable parental consent for under-18s; exemptions exist for healthcare providers and defined purposes. Check whether a PHR app qualifies before relying on them [3] | Mandatory; legal review |
| Cross-border transfers | From May 2027 | Hosting or AI processing abroad must be checked against Rules and any sectoral limits; prefer Indian regions | Mandatory; legal review |
| Data Protection Officer contact, grievance, consent withdrawal as easy as giving | From May 2027 | Publish contact; simple withdraw path | Mandatory |
| Significant Data Fiduciary duties | Possible later | Health data volume may trigger designation: audits, DPIA, India-based DPO | Watch |

## 14.3 ABDM and other requirements

| Requirement | Detail | Class |
|---|---|---|
| ABDM sandbox and milestones | M1 (ABHA), M2 (HIP), M3 (HIU) built against V3 APIs in the sandbox; NHA functional tests; security audit before production; any two milestones needed to exit sandbox per NHA support forum [13] | Mandatory only if integrating with ABDM |
| FHIR R4, NRCeS profiles | India-specific implementation guides; consent artefacts; encrypted data transfer [13] | Mandatory for ABDM |
| Consent artefact handling | No record moves without a valid consent artefact; audit of who accessed what under which consent [13] | Mandatory for ABDM |
| CERT-In incident reporting, IT Act obligations, SPDI Rules transition, telemedicine and e-prescription rules | Not re-verified in this research (NR). Obtain legal confirmation, especially for legal validity of electronic signatures on prescriptions | To verify |
| Medical-device software classification | If outputs resemble diagnosis or triage, regulators may treat software as a device. Keep outputs informational. Not researched (NR) | To verify |

## 14.4 International (future expansion)

**HIPAA** (US, applies to covered entities and business associates; requires administrative, physical and technical safeguards, BAAs with vendors) and **GDPR** (EU/UK; health data is a special category needing explicit consent or another Article 9 basis; right to erasure conflicts with immutable ledgers, which your off-chain-data design avoids) are not re-researched here (NR). Treat both as design inputs: they are broadly consistent with the safeguards in this document, but certification and contracts are separate work.

## 14.5 Recommended best practices beyond the law

- OWASP ASVS Level 2 self-assessment; third-party VAPT before any real users (also required for ABDM production).
- Dependency and secret scanning in CI; weekly updates; SBOM.
- Data minimisation: do not collect Aadhaar numbers; use ABHA tokens when integrated.
- Transparency: public plain-language privacy page; in-app "what AI can and cannot do".
- Incident runbook rehearsed once before launch: contain, assess, notify, report within 72 hours.

SECTION 15

# Roadmap A: 24-48 hour hackathon MVP

## 15.1 Is the ten-step demo achievable?

Verdict: **yes, in about 30-36 focused hours for a solo developer using AI coding agents, and in 24 hours with the cuts marked below.** [ESTIMATE] The risky steps are extraction reliability (step 3) and the chain transaction (step 8) because both depend on external services. Mitigate by pre-recording a backup run and by using synthetic reports you have already tested.

| Step | Demo action | Real or simulated | Risk |
|---|---|---|---|
| 1 | Patient creates account | **Real** (email OTP via Supabase) | Low |
| 2 | Upload report | **Real** (encrypted storage) | Low |
| 3 | AI extracts parameters | **Real** on synthetic PDFs (text layer + vision LLM) | Medium |
| 4 | AI summary | **Real**, non-diagnostic template | Low |
| 5 | Timeline entry | **Real** | Low |
| 6-7 | Second report and comparison | **Real** (SQL deltas) | Low |
| 8 | Hash registered on testnet | **Real** testnet transaction; explorer link live | Medium (faucet, RPC) |
| 9 | Doctor receives access | **Real** grant with expiry; doctor logs in with second account | Medium |
| 10 | Doctor verifies integrity | **Real** browser hash + chain read; tamper test with an edited copy | Medium |

## 15.2 Scope decisions

| Essential (real) | Simulate (say so on stage) | Postpone |
|---|---|---|
| Auth with two roles; upload; AES-GCM encryption; extraction with confirm; trends; compare; hash register/verify; consent grant/revoke; access log; grounded Q&A; (3 canned question types) | Lab issuance with issuer signature (pre-seeded "City Diagnostics" institution, clearly labelled demo); signed prescription (shown as mock screen); emergency access (slide only); ABHA login (screenshot) | ABDM integration; OCR engine hosting; Merkle batching; mobile app; localisation; real lab portal; any real patient data |

**WARNING**

**Be transparent.** Put a visible "Demo environment: synthetic data, testnet" badge in the UI. Do not present the mocked prescription or lab issuance as live integrations, and do not describe a testnet transaction as production. Judges reward clearly bounded honesty.

## 15.3 Development sequence (36 hours)

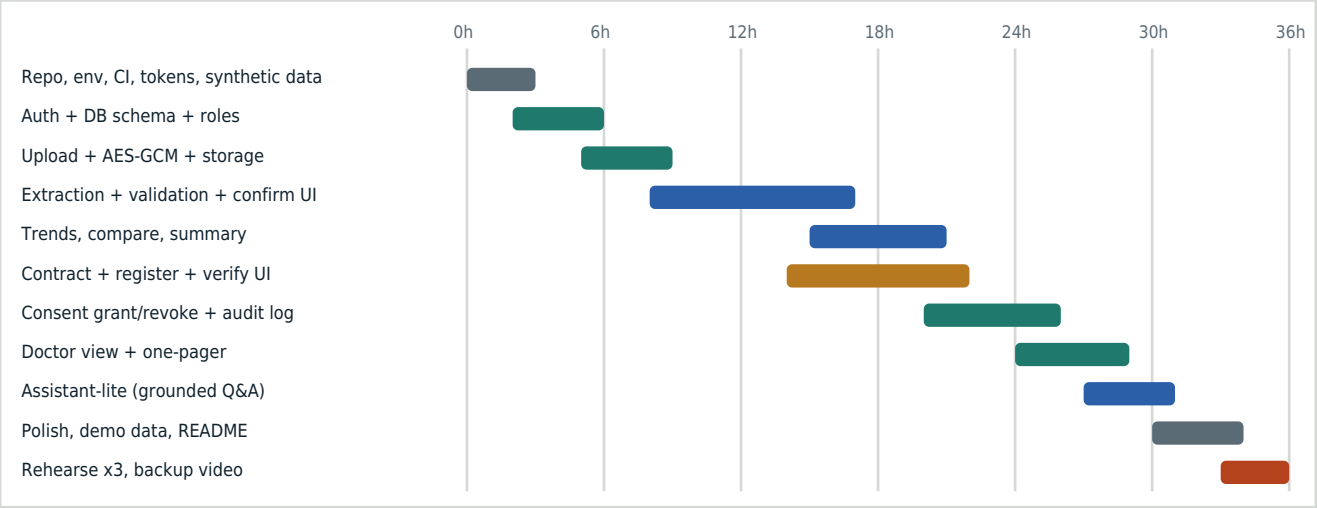



*Figure 9. Suggested solo schedule. Items overlap where an agent can work while you test.*

## 15.4 Team responsibilities (if you have help)

| Role | Owns | Solo fallback |
|---|---|---|
| Full-stack lead | Auth, API, DB, consent, audit | You, hours 2-26 |
| AI engineer | Extraction, validation, summary, Q&A;, synthetic data | You, hours 8-31 (use Gemini CLI heavily) |
| Web3 engineer | Contract, relayer, verify UI, explorer links | You, hours 14-22 |
| Design / pitch | Tokens, seal badge, demo script, slides | Reuse Section 9 tokens; skip custom illustration |

## 15.5 Demo script (5 minutes)

- **0:00** Problem in one sentence: "Medical history is scattered and unverifiable." Show the "Synthetic data, testnet" badge.
- **0:30** Patient signs up, uploads report 1. Show staged progress; extracted values with highlighted source; confirm flagged values; read the summary.
- **1:30** Upload report 2: trend chart updates; open comparison with deltas.
- **2:15** Click Register: show transaction link on the explorer (pre-fund the wallet).
- **2:45** Grant Dr. Rao 24-hour access to two reports. Switch to doctor account: one-page summary.
- **3:30** Verify: green result. Then upload a copy with one changed digit: red mismatch. State precisely what this proves and does not prove.
- **4:15** Back as patient: access log shows the doctor's views; revoke; doctor refresh returns 403.
- **4:45** Roadmap slide: ABDM, signed issuance, DPDP readiness; honest list of simulated parts.

**RECOMMENDATION**

**Pre-flight checklist.** Wake the Render service 5 minutes before; confirm relayer balance and RPC; keep a screen recording of a full successful run; have the tampered file ready; verify Supabase project is not paused.

SECTION 16

# Roadmap B: full product development

[ASSUMPTION] Durations assume one developer at 15-20 productive hours per week using AI coding tools, with legal and audit work outsourced. With two developers, compress by roughly one third. [ESTIMATE]

| Phase | Scope and deliverables | Complexity | Duration | Depends on | Likely blockers |
|---|---|---|---|---|---|
| 1 Foundation | Repo, CI, environments, design tokens, auth, schema, policy layer, audit table, encryption module, observability | Medium | 3-4 wk | Hackathon code as spike | Rewrite vs refactor temptation; KMS setup |
| 2 Core application | Records library, categories, search, sharing flows, doctor view, notifications, export/delete | Medium | 5-7 wk | 1 | Scope creep; UX iteration |
| 3 AI intelligence | Gold set, extraction hardening, Medical Data Toolkit/FHIR, trends with unit conversion, RAG assistant, evaluation harness, private model hosting | High | 6-8 wk | 2 | Model hosting cost; accuracy on phone photos |
| 4 Blockchain integration | Contract audit-lite, relayer, batching with Merkle proofs, audit-root anchoring, mainnet decision and gas policy | Medium | 3-4 wk | 2 | Key management; fee volatility; reorg handling |
| 5 Doctor and lab workflows | Institution onboarding and verification, issuer signatures, lab portal, prescriptions with QR verification, ABHA M1, then M3 | High | 10-14 wk | 4; ABDM sandbox access | Lab pilots; NHA audit timelines [13] |
| 6 Security and compliance | DPDP notices and consent, breach runbook, retention policy, VAPT, legal review, DPO appointment, privacy page | High | 6-8 wk (parallel from phase 2) | Legal counsel | Interpretation of Rules; children's data exemptions |
| 7 Testing | Consent matrix tests, E2E, load test, restore drill, red-team prompts | Medium | Continuous + 3 wk hardening | All | Flaky AI tests |
| 8 Production deployment | Indian-region hosting, backups, monitoring, status page, support process, closed beta of 50-100 users | Medium | 3-4 wk | 6, 7 | Vendor approvals; data-residency choices |
| 9 Future scaling | Emergency access, insurer API, mobile apps, vernacular languages, ABDM M2, enterprise tier | High | Ongoing | 8 | Funding and partnerships |

**NOTE**

**Total:** roughly 9 to 14 months to a compliant, audited closed beta for one developer [ESTIMATE]. For context, an agency estimate for a PHR plus appointment-booking MVP is 10 to 14 weeks and ₹35-55 lakh, and a full ABDM-integrated super-app is 24 to 32 weeks and ₹90 lakh to ₹1.4 crore [21]. A solo AI-assisted build trades money for calendar time and a much narrower scope.

SECTION 17

# Cost and infrastructure analysis

[ASSUMPTION] **Exchange rate assumed: ₹90 per US$1** (confirm on the day). Provider prices are from sources dated 2026 ([14][15][18]); everything else is a planning estimate with wide ranges, not a quote.

## Scenario 1: zero-cost prototype (hackathon, synthetic data)

| Item | Choice | ₹ / month | US$ / month | Limitation |
|---|---|---|---|---|
| AI coding | Gemini CLI + OpenCode + Copilot Free [16] | 0 | 0 | Rate limits; models rotate |
| LLM in product | Gemini free tier [15] | 0 | 0 | Synthetic data only; per-project quotas |
| Database, auth, storage | Supabase Free [14] | 0 | 0 | 500 MB DB, 1 GB files, pauses after ~1 week idle |
| Backend | Render Free [18] | 0 | 0 | 512 MB, sleeps after 15 min |
| Frontend | Vercel Hobby [18] | 0 | 0 | Non-commercial only |
| Blockchain | Polygon Amoy / Base Sepolia faucets [17] | 0 | 0 | Testnet; no real value; faucet limits |
| Domain (optional) | .in/.com | ~70-85 (annualised) | ~1 | Optional |
| **Total** | | **₹0 - ₹100** | **$0 - $1** | Not suitable for real patient data |

## Scenario 2: low-cost MVP (private beta, up to a few hundred users)

| Item | Choice | ₹ / month | US$ / month | Basis |
|---|---|---|---|---|
| Database, auth, storage | Supabase Pro [14] | 2,250 | 25 | 8 GB DB, 100 GB files, no pausing, daily backups |
| Backend API | Render Starter or equivalent [18] | 630 | 7 | Always-on; from $7 |
| OCR / AI worker | Small instance (2 GB RAM) [ESTIMATE] | 2,000-2,500 | 22-28 | PaddleOCR needs more than free 512 MB |
| Frontend | Cloudflare Pages / Netlify Free or Vercel Pro [18] | 0 - 1,800 | 0 - 20 | Commercial use allowed on non-Hobby plans |
| LLM usage | Paid Gemini Flash-class with no-training terms [15] | 300-1,500 | 3-17 | [ESTIMATE] ≈ ₹0.5 per report extraction at published Flash prices |
| Monitoring, email/SMS OTP | Free tiers + small OTP spend | 0-1,000 | 0-11 | |
| Chain gas | Testnet still, or batched mainnet | 0-500 | 0-6 | Measure before mainnet |
| **Monthly total** | | **≈ 5,200 - 10,500** | **≈ 57 - 117** | |
| One-off | Legal review ([ESTIMATE] ₹30,000-1,00,000); VAPT ([ESTIMATE] ₹40,000-1,50,000); domain, design assets | 70,000 - 2,50,000 | 780 - 2,780 | Rough ranges; obtain quotes |

## Scenario 3: production-scale platform (illustrative: ~50,000 monthly users)

| Item | Description | ₹ / month ([ESTIMATE]) | Notes |
|---|---|---|---|
| Managed Postgres (HA + replica) | Indian region, PITR backups | 40,000-80,000 | Supabase Team starts at $599/mo [14]; managed cloud alternative |
| Application compute | 2-4 API and worker instances, autoscaling | 30,000-60,000 | |
| Object storage + CDN | 1-5 TB encrypted, backup copy | 5,000-15,000 | Supabase storage overage is $0.021/GB-month [14] |
| KMS, secrets, WAF, DDoS | Per-patient KEKs, rotation | 15,000-30,000 | |
| Logging and monitoring | One-year retention to satisfy DPDP [3] | 20,000-40,000 | Log volume grows with access events |
| AI inference | Self-hosted GPU for Gemma-class or private API | 30,000-1,00,000 | Largest variable |
| Blockchain | Batched anchoring on mainnet L2, RPC plan | 5,000-20,000 | Batching keeps gas minor |
| Compliance and operations | DPO, legal retainer, annual audit/VAPT amortised, on-call, support | 1,00,000-3,00,000 | People cost dominates |
| **Total** | | **≈ 2.5 - 7.5 lakh** | ≈ US$ 2,800 - 8,300 |

**WARNING**

**Free-tier limitations to remember.** Supabase pauses idle projects and lacks daily backups on the free plan [14]; Render free services sleep and its free Postgres expires after 30 days [18]; Vercel Hobby forbids commercial use [18]; Gemini free quotas are per project, can change without notice, and are not appropriate for private data [15]; testnet tokens are valueless and faucets are rate limited [17]. A free stack is a prototype stack.

SECTION 18

# Final recommendations

## Decisions to lock now

| # | Decision | Rationale |
|---|---|---|
| 1 | Build the hackathon MVP exactly as Section 15 defines; use synthetic data only | Fits the time and privacy constraints |
| 2 | Wedge = verifiable documents + access transparency + clinician one-pager; not "another PHR" | Government and Eka already cover PHR and AI summaries [8][10] |
| 3 | One ORM (SQLAlchemy), one backend (FastAPI), one chain, one LLM provider interface | Simplicity for a solo developer |
| 4 | Off-chain access control; on-chain salted commitments and audit roots only | Honest, DPDP-friendly design |
| 5 | Human confirmation for flagged extractions; non-diagnostic assistant | Patient safety |
| 6 | Plan ABDM (M1 then M3) and DPDP readiness for Phase 2 | Interoperability and 13 May 2027 deadline [1] |
| 7 | Validate the wedge with 15-20 interviews before any funded build | Largest business risk is demand, not technology |

## Kill or pivot criteria

- If most interviewed patients say Aarogya Setu 2.0 or Eka already meets their needs and they would not pay or switch, pivot to **B2B signed-report issuance and verification** for labs and clinics.
- If no lab will pilot signed issuance within three months, reconsider blockchain anchoring entirely and use plain digital signatures plus RFC 3161 timestamps.
- If extraction accuracy on real-world photos cannot reach 85% field accuracy with confirmation, restrict to digital PDFs.

## Your first seven days

| Day | Action |
|---|---|
| 1 | Confirm free-tier limits on provider pages; create accounts; get faucet funds; write AGENTS.md with this PDF's Sections 7, 10, 11, 12, 13 |
| 2 | Generate 10 synthetic reports (varied layouts) and a ground-truth JSON file for each |
| 3-4 | Slice 1-3: auth, schema, upload with encryption (tests first) |
| 5 | Slice 4: extraction on the 10 reports; measure accuracy |
| 6 | Slice 5-6: trends, compare, contract on testnet |
| 7 | Slice 7-8: consent, audit log, verify page; rehearse the demo once |

SECTION 19

# Implementation checklist

## Before coding

[ ] Confirm every free-tier limit on its official page
[ ] Create repo, AGENTS.md, .env.example, secrets policy
[ ] Create Supabase project (note keepalive plan) and a Render service
[ ] Faucet-fund a relayer wallet on the chosen testnet
[ ] Generate synthetic report set and ground truth

## Foundation

[ ] FastAPI app factory, config, error handling
[ ] SQLAlchemy models + Alembic baseline
[ ] Supabase JWT verification and role mapping
[ ] policy.py with can_read and tests
[ ] crypto.py: AES-256-GCM envelope encryption with tests
[ ] Audit events with hash chain

## Records and AI

[ ] Upload endpoint, size/type validation, encryption, storage
[ ] Text-layer extraction then vision/OCR fallback
[ ] Schema-constrained structuring with validation and confidence
[ ] Confirm UI with source highlighting
[ ] Observations table, series and compare endpoints
[ ] Summary generator from validated data
[ ] Assistant tools: SQL and vector, both policy-scoped; refusal tests

## Blockchain

[ ] DocumentRegistry contract and Hardhat tests
[ ] Deploy to testnet; record address and ABI
[ ] Relayer service with retry and pending state
[ ] Browser verifier (Web Crypto + viem read)
[ ] Tamper test in E2E

## Access and doctor

[ ] Grant/revoke with expiry and immediate effect
[ ] Patient access-log timeline
[ ] Doctor patient list, summary, compare
[ ] Consent matrix test across roles and endpoints

## Quality and launch

[ ] Extraction gold-set regression in CI
[ ] Playwright E2E for demo path
[ ] Demo badge; backup recording; pre-flight list
[ ] Privacy page and AI limitations notice

[ ] For beta: KMS, backups and restore drill, VAPT, legal review, breach runbook

SECTION 20

# Research references and source-quality notes

References are numbered to match in-text citations. Retrieval date: 7 November 2026. Primary sources (Google, PIB, Alchemy and Polygon docs, Supabase, journals) are preferred; the rest are secondary and flagged.


| # | Source |
|---|---|
| 1 | ConsentOS, "DPDP Act Enforcement Date & Compliance Deadlines (2026-27)", consentos.in/learn/dpdp-compliance-timeline/ |
| 2 | SCC Online, "Digital Personal Data Protection Rules, 2025: key highlights", scconline.com/blog/post/2025/12/26/digital-personal-data-protection-rules-2025-key-highlights/ |
| 3 | Mondaq, "A closer look at the DPDP Rules 2025", mondaq.com/india/data-protection/1706890/a-closer-look-at-the-dpdp-rules-2025 |
| 4 | Press Information Bureau, ABDM progress document (July 2026), static.pib.gov.in/WriteReadData/specificdocs/documents/2026/jul/doc202676912801.pdf |
| 5 | Kashmir Life, "Over 1.12 Crore ABHA Accounts Created in J&K;, Parliament Told" (95.99 crore ABHA as of 31 Jul 2026), kashmirlife.net/over-1-12-crore-abha-accounts-created-in-jammu-kashmir-parliament-told-446964/ |
| 6 | Digital Health News, "India's Digital Health Progress Across States in 2026" (data as of 12 Aug 2026), digitalhealthnews.com |
| 7 | IANS/NewKerala, "Ayushman Bharat hits 100 crore health records linked" (22 May 2026), newkerala.com/news/a/ayushman-bharat-milestone-100-crore-health-records-linked-202.htm |
| 8 | Google India, "Bringing AI to India's digital health infrastructure" (29 Jun 2026), blog.google/intl/en-in/company-news/india-aarogya-setu-gemma-medical-data-toolkit/ |
| 9 | OpenGov Asia, "India launches Aarogya Setu 2.0 and new digital health platforms", opengovasia.com/india-launches-aarogya-setu-2-0-and-new-digital-health-platforms-to-expand-connected-care/ |
| 10 | Eka Care product pages and app listings (apps.apple.com/in/app/eka-care/id1561621558; product.eka.care); toolmage.com/en/tool/eka-care/ |
| 11 | SoftwareFinder, "eka.care pricing" (Eka Doc Plus ₹16,999/yr; Pro ₹18,749/yr; Clinic Pro ₹1,00,000/yr), softwarefinder.com/emr-software/eka-care |
| 12 | Inc42, "Practo in talks to acquire HealthPlix", inc42.com/buzz/practo-in-talks-to-acquire-healthtech-saas-startup-healthplix/; HealthPlix (healthplix.com); Apptunix, "Practo business model" (secondary sources) |
| 13 | Nirmitee, "ABDM integration milestones M1-M4" and "M1-only certificate rule" (nirmitee.io/blog); Sigosoft ABDM guide; Piramal Swasthya AMRIT ABDM integration docs (piramal-swasthya.gitbook.io). Vendor sources: timelines are indicative |
| 14 | Supabase pricing (supabase.com/pricing); itpathsolutions.com/supabase-free-tier-limits (May 2026); selfhost.dev/blog/supabase-pricing-explained (Aug 2026) |
| 15 | CometAPI, "Gemini API free tier 2026" (2 Nov 2026); Morph, "Gemini API pricing" (25 Oct 2026); RapidDev Gemini limits matrix. Secondary sources; verify on ai.google.dev |
| 16 | KDnuggets, "5 Free AI Coding Agents You Should Try in 2026"; github.com/ShaikhWarsi/free-ai-tools; github.com/feimacode/copilot-alternatives; morphllm.com/best-ai-cli-tools-2026 |
| 17 | Alchemy faucets docs (alchemy.com/docs/faucets.md); Polygon docs (docs.polygon.technology/tools/gas/matic-faucet.md); QuickNode Amoy faucet; OnFinality Amoy guide; 1inch testnets overview (blog.1inch.com/testnets-blockchains) |
| 18 | flaviocopes.com/hosting-free-tiers (Sep 2026); stork.ai "How to host a website for free 2026" (1 Nov 2026); techplained.com best free hosting |
| 19 | Neveditsin et al., "Compact Multimodal Language Models as Robust OCR Alternatives for Noisy Textual Clinical Reports", arXiv:2511.13523 / EACL 2026 Industry Track; Unstract on PP-OCRv6 |
| 20 | O'Donoghue et al., "Design Choices and Trade-Offs in Health Care Blockchain Implementations", JMIR 2019;21(5):e12426; "Blockchain Personal Health Records: Systematic Review", JMIR 2021;23(4):e25094; Meinert et al., JMIR 2019;21(2):e12439 |
| 21 | RaftLabs, "Cost to build a health super-app like Eka Care: India ABDM guide", raftlabs.com/blog/cost-to-build-app-like-ekacare (agency estimate) |
| 22 | Nomic Foundation, hardhat-viem 3.0.0 release notes (first release of Hardhat 3), hardhat.org; npm @nomicfoundation/hardhat-viem |

## Known conflicts and unverified areas

- DPDP Rules notification date: 13 Nov 2025 per commencement notification summaries; some outlets say 14 Nov [1][2].
- Supabase free egress: 5 GB in most sources, 10 GB in one August 2026 article [14].
- Gemini free tier: models and daily limits differ across third-party pages and are described as project-specific [15]. Use your AI Studio dashboard.
- Free coding-tool quotas and the future of Gemini CLI (transition to an Antigravity CLI) come from community repositories, not vendor pages [16].
- Not researched afresh: Apple Health, Microsoft healthcare, OpenMRS/Bahmni, MedRec internals, CERT-In directions, IT Act/SPDI transition, telemedicine and e-prescription law, medical-device software rules, HIPAA and GDPR specifics. Marked NR where used.
- Cost figures for legal review, VAPT and production scenarios are planning estimates without supplier quotes.